

Ответы на вопросы по дисциплине «Методы сбора и обработки данных из открытых источников» (OSINT)

Как пользоваться этим файлом. Документ состоит из трёх частей. **Часть 1** — подробные, «разжёванные» ответы на все вопросы из списка (объяснения от простого к сложному). **Часть 2** — вопросы из всех 9 практических работ: коротко что делается в практике и ответы на контрольные вопросы/вопросы для защиты. **Часть 3** — «шпаргалка на 20 минут перед сном»: вся главная теория и суть каждой практики очень кратко. Сначала прочитайте Часть 3, потом утром Части 1–2 пойдут гораздо легче. Везде, где это важно, я объясняю термины с нуля. Если встречаете незнакомое слово — оно почти всегда расшифровано рядом или в Части 3.

ЧАСТЬ 1. Подробные ответы на вопросы из списка

1. Что такое OSINT и какие технологии используются для его проведения?

OSINT (Open Source INTelligence, «разведка по открытым источникам») — это поиск, сбор и анализ информации, которая находится в открытом, условно-открытом или полуоткрытом доступе: сайты, соцсети, новости, документы, форумы, открытые базы. Главное слово здесь — «открытые»: OSINT не предполагает взлома, доступа к секретным данным или незаконного проникновения.

Идея старая. Ещё до интернета разведки мира получали до 80% данных из открытых источников — газет, радио, телепередач, интервью. Классический пример: в конце 1950-х ЦРУ узнало о схеме электрификации Урала и предприятиях ядерной промышленности благодаря обычной фотографии в журнале «Огонёк». В эпоху интернета этот подход превратился в целую отрасль.

Важно понять: в OSINT всё решает квалификация аналитика, инструменты вторичны. Около 90% информации даёт обычное внимательное чтение постов, новостей, комментариев. Ключом к разгадке может стать мелочь — расположение теней на фото или необычное время активности человека в соцсети.

Технологии (способы расширения «информационной воронки»):

- **Метаданные файлов** — скрытые данные внутри документов и фото (автор, дата создания, ПО, иногда геолокация);
- **Поиск по изображениям** — проверка, действительно ли фото относится к событию;
- **Непубличная документация** — документы, случайно оставленные в открытом доступе (например, в открытых папках Google Docs);
- **Данные о домене** — e-mail, телефоны, технологии сайта, сертификаты, субдомены;
- **Интернет вещей** — индексация устройств: серверов, роутеров, веб-камер (через Shodan);
- **Google Dorks** — поисковые запросы со специальными операторами.

Инструменты: Maltego (визуализация связей), FOCA (анализ метаданных), Shodan (поиск устройств), theHarvester, Recon-ng, SpiderFoot, Maigret/Sherlock (поиск по никнейму), Emailsherlock и др. Инструментов сотни, и почти все легальные и бесплатные.

2. Какие цели могут преследовать лица, применяющие OSINT?

OSINT нейтрален: «работает в обе стороны». Цели бывают совершенно разные:

Законные и полезные:

- **Журналистские расследования** — на инструментах OSINT базируется около 90% современных расследований;
- **Информационная гигиена** — большинство фейковых новостей легко опровергается поиском по изображениям и источникам;
- **Защита от мошенничества** — проверить, не используется ли для «сбора денег на операцию» фото с фотостока;
- **Обоснованные бытовые решения** — проверить работодателя, исполнителя, заказчика (нет ли жалоб, не накручены ли отзывы);
- **Конкурентная разведка и маркетинг** — изучение аудитории, рынка, конкурентов;
- **Кибербезопасность** — компания изучает свой собственный «цифровой след», чтобы понять, что о ней видно снаружи (защитный OSINT);
- **Поиск пропавших людей** — например, соревнования Trace Labs Search Party.

Сомнительные и вредоносные:

- **Подготовка целевых атак** — разведка перед взломом организации;
- **Социальная инженерия и мошенничество** — сбор данных о жертве для обмана;
- **Преследование (сталкинг)** — отслеживание конкретного человека;
- **«Чёрный PR»** — подрыв репутации конкурента.

Вывод: одна и та же методика может применяться добросовестно (журналистика, защита) и недобросовестно (мошенничество, атаки). Ответственность за это несёт сам исследователь.

3. Какие методы защиты от OSINT существуют?

Честный ответ из лекций: **многие специалисты считают, что полностью защититься от OSINT невозможно**. Анонимность в сети — вещь иллюзорная: ваши данные сравнительно несложно получить, причём не только спецслужбам, а любому, кто потратит время.

Но **работу OSINT-аналитика можно существенно затруднить**. Это называется «снижение цифровой экспозиции» (открытости):

- не заводить лишних соцсетей, минимизировать публикации о себе;
- избегать привязки ИНН, почты и телефона к множеству веб-сервисов;

- минимизировать контакты с государственными и коммерческими сервисами там, где можно;
- следить за метаданными — удалять EXIF из фото перед публикацией;
- использовать разные пароли, менеджер паролей, двухфакторную аутентификацию;
- проверять собственный «цифровой след» сервисами вроде browserleaks;
- для организаций — **публикационная дисциплина**: не выкладывать в вакансиях и презентациях лишние технические детали, удалять устаревшие документы, не публиковать скриншоты с адресами внутренних сервисов.

Отдельно — **управление репутацией в поисковых системах (SERM)**: комплекс мер для исключения или минимизации негативных отзывов в поисковой выдаче.

Реалистичный вывод из лекции: «жизнь шпиона-подпольщика трудна», поэтому большинству людей проще смириться с тем, что мы живём довольно открытой жизнью, и просто соблюдать базовую цифровую гигиену.

4. Что такое целевая атака и какие этапы включает её жизненный цикл?

Целевая (таргетированная) атака — это непрерывный процесс несанкционированной активности в инфраструктуре конкретной атакуемой системы, который киберпреступник управляет в режиме реального времени. В отличие от массовых атак «по площадям», здесь атакующий выбирает конкретную жертву.

Три ключевые особенности целевой атаки:

- **Непрерывность** — атакующий долго сохраняет доступ к ресурсу;
- **Целенаправленность** — много ручной работы, учёт особенностей именно этой инфраструктуры;
- **Нетривиальность** — атаку сложно обнаружить защитными системами (она «нешаблонная»).

Жизненный цикл атаки (названия пришли из военной науки):

1. **Разведка, подготовка** — атакующий ищет точки входа: сканирует публичные веб-приложения, анализирует выдачу поисковиков, находит профили сотрудников и их корпоративные e-mail, готовит план.
2. **Доставка** — доставка вредоносного кода (например, фишинговое письмо с вложением).
3. **Эксплуатация** — использование уязвимости, запуск вредоносного кода.
4. **Закрепление** — «отстук» загруженного кода на управляющий сервер атакующего, создание постоянного доступа (persistence).
5. **Действие** — самое интересное для атакующего: разведка уже внутри сети, перемещение к ценным ресурсам (**lateral movement**, «боковое перемещение»), кража данных (**exfiltration**, незаметный вывод данных).
6. **Противодействие** — этап защиты. В идеале он должен начинаться раньше всех остальных, но на практике жертву часто начинают искать уже после того, как атакующий

скрылся с данными.

Для каждой стадии существуют свои превентивные меры и стратегии ответных действий.

5. Какие техники используются на стадии разведки при проведении атаки?

Стадия разведки — **ключевая для выбора тактики, техник и процедур (TTPs)**. Задача: найти как можно больше потенциальных точек входа и оценить стоимость их использования.

Основные техники:

- **Сбор данных из соцсетей** (Facebook, Twitter, YouTube, ВКонтакте) и их анализ — поиск ключевых сотрудников, их e-mail, технологий компании;
- **Агрегирование информации из интернета** — новости, упоминания, пресс-релизы;
- **Работа с «невидимыми» сегментами веба** — deep web, dark web, hidden web;
- **Мониторинг социальных медиа** — сервисы вроде Socialmention, Hootsuite, YouScan, IQBuzz;
- **Поиск «незакрытых дверей»** — классификация точек входа: серверы и панели на периметре, мобильные устройства сотрудников, облачные аккаунты;
- **Анализ сетевого периметра** — получение диапазона IP-адресов организации (включая IP третьих сторон — провайдеров, подрядчиков);
- **Сканирование портов** — Nmap (эталонный сканер), Masscan;
- **Поиск по e-mail и никнеймам** — Emailsherlock, WhatsMyName (по 280+ сервисам), Maigret (по 2300+ сайтам);
- **Использование Shodan** — поиск открытых сервисов и устройств;
- **Визуализация связей** — Analyst's Notebook, Maltego.

Важная деталь: понятие «сетевой периметр» постепенно размывается из-за облаков и концепции **BYOD** (Bring Your Own Device — сотрудники используют личные устройства для работы). Это усложняет защиту и расширяет возможности атакующего.

6. Что такое Shodan и как он используется для OSINT?

Shodan — это поисковая система не по сайтам, а по **устройствам, подключённым к интернету**: серверам, роутерам, веб-камерам, IoT-устройствам, промышленному оборудованию. Его называют «тёмным близнецом Google».

Как он работает. По сути Shodan — это гибрид `nmap -sV` по всему диапазону IPv4-адресов и поисковика результатов. Специальные роботы (**краулеры**, от crawl — «ползать») постоянно сканируют весь интернет, пытаются подключиться к открытым портам и по **fingerprint** (отпечатку, набору технической информации об устройстве) определяют, какой сервис стоит за этим портом.

Что можно узнать через Shodan:

- открытые порты устройства и какие сервисы на них работают;

- провайдера, геолокацию;
- модель оборудования (например, порт 7547 — это веб-интерфейс «HuaweiHomeGateway»);
- назначение портов (110, 465, 993, 995 — почтовые сервисы).

В Shodan есть **фильтры**, упрощающие поиск (по стране, порту, организации, ПО).

Важная юридическая граница. Сам поиск в Shodan легален. Но через него можно «добраться» до управления чужими системами (камерами, оборудованием). **Любая попытка взаимодействия с этими системами юридически квалифицируется как попытка взлома и наказуема.** Shodan показывает масштаб проблемы (сколько устройств «дырявые») и помогает достучаться до вендора для закрытия уязвимости — но не более того. Из лекции: «не будем печатать "Войну и мир" на чужих сетевых принтерах».

7. Какие проблемы могут возникнуть при геолокации данных?

Геолокация — определение места, где сделано фото или видео. По природным и техническим подсказкам это делать сложно, и вот основные проблемы:

- **Растения растут не только в «своём» ареале.** Можно определить растение, но оно может произрастать и далеко от естественного ареала — например, на фото может быть экспозиция садоводов, высадивших растения из других регионов вручную. Такой «трюк не пройдёт».
- **Климатические факторы не привязаны жёстко к широте.** Линии деревьев резко меняются между умеренными и бореальными широтами, но относительно постоянны между $\sim 32^\circ$ с.ш. и 20° ю.ш., и картина несимметрична вокруг экватора. На высоту «лесной линии» влияют другие факторы — микроклимат, температура.
- **«Глобальный лесной участок» (tree line) непостоянен по высоте.** Высота над уровнем моря, где деревья перестают расти, варьируется от района к району. Чтобы использовать этот признак, нужно уже иметь общее представление о стартовом местоположении.
- **Нужна совокупность признаков.** Один признак (растение, тип почвы) редко достаточен — точность низкая. Нужно сочетать растения, деревья, животных, птиц, с/х культуры, постройки, оборудование.
- **Технические ограничения сервисов.** Например, в игре GeoGuessr (тренажёр геолокации на Google Street View) исключены большинство мест Азии, Африки, Южной Америки, центральной Австралии и Крайнего Севера — туда не доезжали машины Google.
- **Геолокация по IPv6** пока в зачаточном состоянии (по крайней мере в публичных базах), а IP-адрес даёт лишь примерное местоположение.

Вывод: геолокация по природным подсказкам даёт направление, но **редко даёт точный результат без перепроверки и совокупности независимых признаков.**

8. Как можно извлечь данные из фотографии при проведении OSINT?

Извлечь данные из фото можно двумя путями — из **метаданных** и из **самого изображения**.

1. Метаданные (технические данные внутри файла). Самый частый формат — **EXIF** (Exchangeable Image File Format). Это стандарт тегов, которые цифровые камеры и смартфоны встраивают в JPEG-файл. EXIF может содержать:

- модель камеры/телефона;
- дату и время съёмки;
- настройки съёмки;
- **GPS-координаты (геолокацию)** — самое ценное для OSINT.

Другие форматы метаданных: **XMP** (расширяемая платформа метаданных, работает не только с фото), **IPTC** (старый формат, использовался прессой). Инструменты для просмотра: **ExifTool** (свободная программа командной строки, поддерживает EXIF, GPS, IPTC, XMP, GeoTIFF и др.), Exif Pilot, GIMP, XnView, в Windows — «Свойства → Подробности».

2. Анализ самого изображения (содержания):

- **Поиск по изображению** (Google Images, Yandex, TinEye) — проверить, не взято ли фото из сети, где ещё оно встречалось;
- **Геолокация по объектам** — здания, улицы, вывески, дорожные знаки, растения, животные, птицы (приложение Merlin Bird ID опознаёт птицу по фото);
- **Тени** — по теням можно определить время и азимут солнца (сервис SunCalc, ShadowCalculator);
- **Розетки, номерные знаки, тип сельхозкультур** — указывают на страну/регион;
- **Проверка на манипуляции** — сервисы Forensically, FotoForensics, JPEGsnoop используют **анализ уровня ошибок (ELA)** для выявления подделок.

Важно для защиты: перед публикацией фото рекомендуется удалять метаданные, чтобы не «слить» геолокацию и информацию об устройстве.

9. Как проверить достоверность найденных данных?

Проверка достоверности (верификация) — обязательный шаг любого OSINT-исследования. Базовый алгоритм:

1. **Не верить ничему, пока не проверен источник.** Сначала прочитать весь материал целиком, затем выяснить, откуда он.
2. **Оценить надёжность источника.** Если новость с надёжного, всемирно известного ресурса — перейти на сайт первоисточника и проверить, есть ли там та же информация. Например, если новость приписывается Reuters — зайти на reuters.com.
3. **Перекрёстная проверка.** Если источник неизвестен — провести онлайн-поиск: кто ещё опубликовал ту же новость. Если её подтверждает несколько независимых авторитетных

ресурсов — скорее всего, это правда. Если нет — отказаться от использования или проверять дальше.

4. **Поиск по изображениям.** Проверить, не используется ли фото из другого события или с фотостока (частый признак мошенничества и фейков).
5. **Анализ метаданных** — дата создания документа/фото, ПО, автор. Часто помогает отличить реальный документ от фейкового.
6. **Использовать цикл OODA / НОРД** (Observe-Orient-Decide-Act, наблюдение-ориентация-решение-действие): наблюдать находку → строить гипотезу → искать дополнительную информацию для подтверждения → решать.
7. **Специальные сервисы фактчекинга** — Snopes, Hoaxy, FactCheck, TruthOrFiction, InVID Verification Plugin.
8. **Указывать уровень уверенности** — разделять «подтверждено несколькими независимыми источниками», «подтверждено одним источником», «вероятно по совокупности признаков», «требуется проверки».

Главный принцип: **один источник или одно совпадение — это ещё не доказательство.** Достоверность появляется при совокупности независимых подтверждений.

Примечание: тема психологического давления и мошенничества затрагивается дальше — это чувствительная область. Если вы лично сталкиваетесь с мошенничеством или давлением, важно обращаться за поддержкой к близким и официальным структурам.

10. Какие психологические концепции могут быть использованы в социальной инженерии?

Социальная инженерия (социотехника) — набор приёмов психологической манипуляции, вынуждающих жертву сделать то, что нужно манипулятору. В отличие от обычной информационной безопасности (которая берёт концепции из информатики), социальная инженерия заимствует концепции **из психологии**, поэтому специалист должен хорошо разбираться в человеческом поведении.

Основные психологические концепции (из лекции):

- **Влияние** — нейтральный термин: деятельность, которая побуждает других к определённому результату. Может быть положительным или отрицательным. Пример: врач убеждает пациента вести здоровый образ жизни.
- **Манипуляция** — пагубное влияние, обычно направленное на причинение вреда. За пределами психологии люди не различают влияние и манипуляцию, но среди специалистов это разные вещи.
- **Взаимопонимание (раппорт)** — взаимное доверие, «дружеские, гармоничные отношения», характеризующиеся согласием и сопереживанием. Установление раппорта делает общение лёгким.
- **Шесть принципов влияния доктора Чалдини** (см. вопрос 12) — авторитет, привлекательность, срочность/дефицит, постоянство/последовательность, социальное доказательство, взаимность.

- **Симпатия и эмпатия:** *симпатия* — забота о человеке, которому плохо; *эмпатия* — способность испытывать те же чувства, что и другой, как будто вы на его месте. Эмпатия — это общие эмоции, симпатия — сочувствие с вашей стороны. И то и другое помогает установить раппорт.

Понимание этих концепций нужно специалисту по ИБ прежде всего для **защиты**: чтобы распознавать, когда эти приёмы применяют против него или его организации.

11. Как влияют манипуляции на результаты социальной инженерии?

Ключевое различие: **влияние** — нейтральная или положительная мотивация; **манипуляция** — пагубное влияние, направленное на причинение вреда.

В социальной инженерии и злоумышленники, и благонамеренные пентестеры часто **используют манипуляции вместо влияния** — но, как отмечается в лекции, обычно «из-за недостаточной подготовки или по недомыслию», а не сознательно.

Как манипуляции влияют на результат:

- **Краткосрочно** манипуляция может «сработать»: жертва выполнит нужное действие (перейдёт по ссылке, выдаст данные).
- **Но в этической/профессиональной социальной инженерии** (пентест по контракту) манипуляция — плохой выбор: воздействие на реальных людей может выйти за пределы ноутбука и **причинить психологический вред**. Цель этического теста — обучить организацию, а не травмировать сотрудников.
- Манипуляция разрушает раппорт (доверие), а без доверия долгосрочные сценарии не работают.
- Манипуляция повышает риск, что атаку **заметят и сообщат о ней** — а значит, увеличивает «обнаружение» в плохом смысле и портит репутацию исполнителя.

Профессиональный вывод: грамотный специалист по социальной инженерии стремится использовать **влияние**, а не манипуляцию, и всегда соблюдает границы — если человек просит прекратить разговор, нужно остановиться. Манипуляция допустима для понимания механики атаки (чтобы защищаться), но не как способ «сеять хаос» без продуманного плана и согласия.

12. Какие принципы влияния доктора Чалдини могут быть применены в социальной инженерии?

Психолог **Роберт Чалдини** в книге «Психология влияния» описал **шесть принципов влияния**. В социальной инженерии их применяют так:

1. **Авторитет.** Люди склонны выполнять просьбы того, кто наделён властью, или когда верят (правдиво или под ложным предлогом), что так делает авторитетная фигура. В вишинге злоумышленник звонит и говорит: «действую по распоряжению генерального директора / директора по ИБ / в соответствии с законом».
2. **Привлекательность.** Люди охотнее помогают тем, кого считают милым и приятным. Продавец делает комплименты по поводу одежды, внешности, интеллекта, чтобы

завоевать расположение.

3. **Срочность и дефицит.** Если есть риск чего-то не получить, человек хочет этого сильнее. Искусственный таймер «осталась одна минута, иначе вы выбываете», «осталось мало товара» — заставляют действовать быстро, не раздумывая. Фишеры предлагают «слишком хорошую, чтобы быть правдой» сделку с оговоркой действовать немедленно.
4. **Постоянство и последовательность.** Люди ценят стабильность и не любят перемены. Манипулятор подчёркивает, что он «всегда заботился о клиентах», «что обещано, то и сделано» — создаёт образ предсказуемого, надёжного партнёра.
5. **Социальное доказательство.** Мы делаем что-то, потому что «остальные считают это нормальным, уместным или статусным». Злоумышленник убеждает: «все эффективные сотрудники выполняют это действие», «успешные люди вашего возраста покупают такую машину». Социальное доказательство можно **сфабриковать с помощью OSINT**: узнать, кто в компании влиятелен, и написать «авторитетный человек восторженно о вас отзывался и дал ваш контакт».
6. **Взаимность.** Мы охотнее помогаем тем, кто помог нам. Социальный инженер сначала оказывает услугу (сфотографировал пару на фоне яхты), а потом просит что-то взамен — и человек чувствует себя обязанным, даже если ему самому это невыгодно.

Знание этих принципов нужно, чтобы **распознавать манипуляцию** и обучать сотрудников ей противостоять.

13. В чём заключаются этические рамки при проведении OSINT?

Этические рамки OSINT мягче, чем у социальной инженерии (вы не взаимодействуете с объектами напрямую), но они есть. Главные принципы:

- **Не собирать всё подряд без разбора.** Хотя информация открыта, её сбор может повлиять на благополучие людей.
- **Защита данных и «цепочка хранения» (chain of custody).** Нужно продумать, как долго хранить собранные данные, как их уничтожить, какую ценность им присвоить, что будет при утечке. Концепция цепочки безопасного хранения (из криминалистики) требует хранить улики в безопасном месте с момента сбора до уничтожения, с фиксацией доступа.
- **Цифровая гигиена** — последовательное применение лучших практик безопасности: антивирус, уникальные надёжные пароли, менеджер паролей, многофакторная аутентификация. Это страхует от сомнений в надёжности ваших данных, особенно если они для суда.
- **Соблюдение законодательства.** Только вы несёте ответственность за соблюдение законов местности, где действуете вы и ваш объект. В некоторых странах OSINT-деятельность частных лиц ограничена строже, чем юрлиц. Перед началом лучше проконсультироваться с юристом.
- **Особые полномочия — особая осторожность.** Сотрудники правоохранительных органов и частные детективы имеют более широкие возможности, но должны знать применимые законы. ACLU ещё в 2012 году предупреждал об опасности использования больших данных и OSINT для «выявления преступников до того, как они нарушат закон».

- **Правила опроса людей:** всегда позволять человеку отказаться от разговора; не давить слишком сильно; деликатные вопросы задавать в безопасном месте; если задела человека за живое — успокоить его; сообщать руководству о сложных ситуациях.

Главный принцип: законность («белая зона») и уважение к людям, чьи данные вы анализируете.

14. Какие виды кибератак (спам, вирусы, фишинг, вымогательство) могут быть связаны с OSINT?

OSINT часто **предшествует** этим атакам: собранная информация делает атаку из «случайной» — «целенаправленной» и многократно повышает её шансы.

- **Спам** — массовые анонимные непрошеные рассылки по e-mail и SMS. Обычно реклама, но может быть носителем вирусов или фишинга. 90–99% спама уничтожают фильтры. Спам использует социотехнику: тема «мимикрирует» под письмо от знакомого; письмо может содержать «шпионский пиксел» 1×1 для слежки; обратный адрес легко подделать; по ссылке «отписаться» нельзя переходить — она подтверждает спамеру, что адрес «живой».
- **Вирусы (вредоносные программы)** — троянские программы, кейлоггеры, руткиты, шпионское ПО. Распространяются через вложения, ссылки, пиратское ПО. OSINT помогает подобрать «приманку» (название, тему), которая заставит конкретного сотрудника открыть вложение.
- **Фишинг** (от fishing — «рыбная ловля») — выуживание у пользователя паролей, логинов, номеров карт. Цель — кража денег. Крючки: «деньги с неба» (афера-419), «перерасчёт пенсии для пенсионеров», «чудо-лекарства», «супермодные товары», «инвестиции в стартап». OSINT позволяет сделать фишинг целевым (**spear phishing**): использовать имена коллег, реальные события компании, интересы жертвы.
- **Вымогательство** — крючком служит страх. Классика: письмо от «хакера»: «вот твой пароль, я установил шпионскую программу, видел через камеру, как ты смотрел нехороший контент — плати биткойны». Никакого видео нет, а пароль обычно «слит» с какого-то старого пиратского сайта. Сюда же — программы-вымогатели (ransomware), шифрующие файлы.

Связь с OSINT прямая: чем больше атакующий знает о жертве (имена, e-mail, технологии, интересы, события), тем убедительнее и опаснее любой из этих видов атак.

15. Что включает в себя этическая социальная инженерия?

Этическая социальная инженерия — это применение приёмов социальной инженерии в рамках закона и контракта (например, тест на проникновение), с защитой реальных людей от вреда.

Что она включает:

- **Контракт и техническое задание (ТЗ).** Должно быть письменное разрешение от лица, уполномоченного его давать.
- **Соблюдение границ — безоговорочно.** Если люди просят прекратить разговор или заканчивают его — нужно остановиться.

- **Понимание юридических аспектов.** Два главных:
 - **Спуфинг** (введение в заблуждение, подмена номера звонящего) — в большинстве стран подмена номера запрещена; если вы звоните только на служебные номера заказчика по контракту, вы, скорее всего, чисты перед законом;
 - **Запись разговоров** — особенно сложно, когда запись ведётся без согласия и даже без уведомления второй стороны.
- **Учёт географии.** Нужно учитывать физическое местонахождение людей и серверов: можно случайно нарушить законы чужой страны.
- **Защита психики объекта.** Воздействие выходит за пределы ноутбука; нужно гарантировать, что человек не подвергнется психологическому стрессу или иному вреду. Лучший способ — установить чёткие границы.
- **Цель — обучение, а не вред.** В идеальном случае атакующего должны «поймать», а организация должна научиться на его действиях.

Главное отличие от обычного пентеста: при тестировании сетей жертвы «оставляют работу на работе», а социальная инженерия затрагивает людей и за пределами рабочего места — поэтому требует особой осторожности.

16. Какие меры безопасности можно принять для защиты от атак, основанных на OSINT?

Меры делятся на технические, организационные и поведенческие.

Технические:

- антивирус + персональный брандмауэр (фаервол) как первая линия защиты;
- антивредоносное ПО (Spybot, Malwarebytes) дополнительно к антивирусу;
- регулярное обновление ОС и **всех** программ (не только Microsoft);
- учётная запись с ограниченными правами для повседневной работы (не администратор);
- надёжные уникальные пароли + менеджер паролей + многофакторная аутентификация;
- шифрование дисков (VeraCrypt, BitLocker) и данных перед загрузкой в облако;
- VPN в общественных сетях, осторожность с публичным Wi-Fi;
- закрытие неиспользуемых портов и служб, пароль на BIOS/UEFI;
- заклеивание веб-камеры.

Организационные (для компании):

- **публикационная дисциплина** — не раскрывать в вакансиях, презентациях, на help-страницах лишние технические детали (стек, имена сервисов, схемы);
- удаление устаревших публичных документов и страниц;
- обучение сотрудников распознавать фишинг и социальную инженерию;
- регулярный аудит собственного «цифрового следа» (защитный OSINT);

- системы обнаружения атак, в том числе «после взлома» (post-breach), например ханипоты («ловушки»).

Поведенческие:

- не открывать вложения и ссылки от неизвестных отправителей;
- не «отписываться» от спама;
- проверять входящие звонки «из банка», не сообщать данные карты и коды из SMS;
- критическое мышление при «срочных» и «слишком выгодных» предложениях.

Главная идея: ни одна мера не даёт 100% защиты — нужен **комплекс** мер плюс информированность людей.

17. Чем отличаются стадии разведки и эксплуатации в рамках атаки?

Это две разные стадии жизненного цикла атаки, и они принципиально отличаются.

Стадия разведки (reconnaissance):

- **Цель** — собрать информацию, найти точки входа, выбрать тактику.
- **Что происходит:** изучение публичных веб-приложений, поиск сотрудников и их e-mail, сканирование периметра, сбор OSINT, анализ соцсетей.
- **Воздействие на объект:** минимальное или пассивное. В чистом OSINT — вообще без прямого контакта.
- **Заметность:** низкая, атаку трудно обнаружить, потому что внешне это похоже на обычную активность.
- **Результат:** план действий и набор векторов атаки.

Стадия эксплуатации (exploitation):

- **Цель** — реально использовать найденную уязвимость, получить доступ.
- **Что происходит:** запуск эксплоитов, выполнение вредоносного кода, проникновение в систему.
- **Воздействие на объект:** активное, прямое вмешательство в инфраструктуру.
- **Заметность:** выше — это уже несанкционированное действие, которое защитные системы могут зафиксировать.
- **Результат:** фактический доступ в систему, после чего идут закрепление и действие.

Коротко: **разведка** — это «**смотрю и собираю**», **эксплуатация** — это «**вламываюсь и использую**». Разведка отвечает на вопрос «как и куда атаковать», эксплуатация — это уже сама атака. Именно поэтому OSINT (пассивная разведка) законен, а эксплуатация без разрешения — преступление.

18. Какие этапы подготовки к атаке в OSINT следует выполнить перед началом работы?

Перед любой атакой с применением социальной инженерии нужно чётко усвоить процесс — иначе возможны проблемы с законом или вред психике объекта. Этапы подготовки:

1. **Согласование с клиентом.** Координация действий с заказчиком, менеджером или другой командой. Нужно чётко знать, что можно и чего нельзя.
2. **Ознакомление с задачей (определение объёма работ).** Выяснить: кто контактное лицо; сроки (сколько часов, в какое время суток/недели, запретные периоды); юридические аспекты; объём атаки (сколько звонков, писем).
3. **Оформление технического задания (ТЗ).** Часть контракта, где явно указано, что вы уполномочены и не уполномочены делать: разрешённые/запрещённые предлоги, e-mail-адреса, исходящие и целевые IP. Все тестировщики и компания должны быть упомянуты поимённо.
4. **Юридическая защита.** Письменное разрешение от уполномоченного лица; для внешних исполнителей — страховка от ошибок и упущений (E&O, она же страхование профессиональной ответственности PLI).
5. **Определение целей тестирования.** Зачем нужен тест: обоснование новых средств защиты, оценка персонала, проверка соблюдения правил, оценка работы службы безопасности.
6. **Определение методов.** Какие именно техники: домен-двойник с опечаткой, выдача себя за поставщика/клиента, вишинг + фишинг, сбор учётных данных и т.д.
7. **Разработка предложений (см. вопрос 19).**

Поучительный пример из лекции: в сентябре 2019 г. пентестеров компании Coalfire арестовали при попытке проникнуть в здание суда в Айове — заказчик не ожидал физического проникновения. Это показывает, насколько важно правильное ознакомление с задачей.

19. Какие методы разработки удачных предложений можно использовать в OSINT?

Предлог (pretext) — это легенда, под которой социальный инженер взаимодействует с жертвой. Удачный предлог превращает атаку из случайной в целенаправленную.

Методы разработки:

- **Найти события в окружении жертвы,** которые можно использовать. Например, заявить, что вы из организации, предоставляющей компании-жертве облачное хранилище или почтовый сервер, и запросить данные «в связи с инцидентом безопасности».
- **Изучить местные соцсети** — страницы и группы, чтобы собрать дополнительный OSINT.
- **Купить местные газеты,** если есть время.
- **Прогуляться по городу** (если близко) — поискать листовки, плакаты о подходящих событиях.

- **Найти общие интересы среди целей** — кто-то любит пешие прогулки, бег, гонки с препятствиями, рок-фестивали.
- **Узнать про корпоративные команды** — есть ли команда по боулингу или софтболу, в каких лигах играют, против кого.

После сбора информации:

- разработать **3-5 лучших сценариев и предложений** и дать клиенту выбрать;
- подтвердить **временные рамки** атаки, но не точное время — это держит клиента в напряжении и даёт элемент неожиданности.

Хитрый приём из лекции: если контракт разрешает перезвонить без согласования, когда «попросили перезвонить», то во время вишинг-звонка можно создать громкий фоновый шум и симитировать обрыв связи — собеседник сам попросит перезвонить. При повторном звонке его бдительность уже ослаблена.

20. Какие фазы атаки включают в себя последовательный подход?

Все этичные хакеры обычно следуют **определённой последовательности фаз атаки** — это гарантирует, что вся нужная информация будет собрана и использована. Последовательность (из лекции о подготовке к атаке):

1. **Разведка (reconnaissance)** — выявление ключевых сотрудников, поставщиков, технологий, доменов, e-mail-адресов.
2. **Сканирование и перечисление (scanning and enumeration)** — обнаружение хостов, портов, сервисов.
3. **Получение доступа (gaining access)** — собственно проникновение.
4. **Поддержание доступа (maintaining access)** — закрепление в системе.
5. **Удаление следов (covering tracks)** — сокрытие присутствия.
6. **Составление отчёта (reporting)** — оформление результатов.

В лекции более развёрнутый учебный фреймворк социальной инженерии состоит из этапов: **Обзор → Разведка → Проектирование и согласование → Реализация → Обнаружение → Измерение → Составление отчёта** (каждый разбирается в вопросах 21-27).

Дополнительно используется **цикл НОРД / OODA** (Наблюдение-Ориентация-Решение-Действие): наблюдать находки → строить гипотезу (ориентация) → искать подтверждающую информацию → решать, что делать → переходить к действию. Цикл можно повторять итеративно. Этот цикл применим к любой атаке — будь то проникновение на веб-сервер или получение прав администратора.

21. Что включает в себя фаза обзора в атаке по методике OSINT?

Фаза обзора — это первый этап фреймворка, этап **определения объёма задачи** социальной инженерии.

На этой фазе исполнитель **задаёт вопросы своему клиенту**, чтобы убедиться, что у него есть вся необходимая информация для выполнения работы.

Что выясняется на фазе обзора:

- кто будет контактным лицом со стороны заказчика;
- сроки выполнения: сколько часов отведено, в какое время суток/недели/месяца можно тестировать, какие есть запретные периоды;
- объём атаки: количество звонков, писем;
- юридические аспекты, формулировки в договоре, защищающие исполнителя;
- разрешённые и запрещённые предлоги, целевые и исходящие IP-адреса, e-mail.

Результат фазы обзора фиксируется в **техническом задании (ТЗ)** — части контракта, где чётко указано, что исполнитель уполномочен и не уполномочен делать.

Почему это важно: фаза обзора **задаёт тон всему взаимодействию**. Неправильная оценка работы на этом этапе создаёт проблемы обеим сторонам — лишние звонки в неподходящее время, некачественное выполнение, ущерб репутации исполнителя. Поэтому ключевой навык на этой фазе — **умение задавать правильные вопросы**. Для этого в методичках используют специальную рабочую таблицу с вопросами.

22. Какие методы разведки могут быть использованы в ходе атаки по методике OSINT?

На этапе разведки (после подписания контракта, в указанные сроки) задача — выявить максимум данных об объекте. Методы:

- **Поиск ключевых сотрудников** — кто работает в компании, их роли;
- **Поиск поставщиков, партнёров, продавцов** и используемых технологий;
- **Определение доменов и поддоменов** организации;
- **Сбор e-mail-адресов** и определение **стандартного синтаксиса** корпоративной почты (например, имя.фамилия@company.com) — это позволяет «вычислить» адреса других сотрудников;
- **Анализ соцсетей** — профили сотрудников, их интересы, события;
- **Сбор OSINT** в рамках отведённого времени (не тратить 12 часов на одну цель, если на всю атаку отведено 4 часа);
- **Сканирование периметра** — Nmap, Masscan, Shodan;
- **Поиск по e-mail и никнеймам** — Maigret, WhatsMyName;
- **Использование цикла НОРД** для итеративного уточнения гипотез.

Важный нюанс: некоторые организации поддерживают хорошую **операционную безопасность (OpSec)** — не используют соцсети или даже намеренно размещают **ложную/вводящую в заблуждение информацию** в своих аккаунтах, чтобы сбить с толку атакующего. Это называется **активной дезинформацией**. Поэтому собранные данные нужно перепроверять.

При условии соблюдения контракта и временных рамок «никакой объём OSINT не будет излишним» — чем больше достоверной информации, тем выше шанс успеха.

23. Как происходит проектирование и согласование в рамках атаки по методике OSINT?

Проектирование и согласование — фаза фреймворка между разведкой и реализацией.

Что происходит:

- Нужно **убедиться, что собранная OSINT-информация актуальна** — данные могли устареть.
- На основе собранной информации **разработать сценарии и предлоги** атаки.
- **Согласовать предлоги с клиентом:** показать клиенту от 3 до 5 лучших вариантов предлогов и дать ему самому выбрать, какой использовать.
- По возможности **подтвердить временные рамки** атаки (но не точное время — это даёт элемент неожиданности).
- Использовать собранную информацию так, **чтобы помочь сотрудникам организации-жертвы расти и учиться.**

Ключевая идея этой фазы — этическая направленность. Даже если исполнитель пытается получить доступ к системе или информации, в идеальном случае **его должны поймать**, а сотрудники должны **научиться** на его действиях. То есть проектирование строится не вокруг «как навредить максимально», а вокруг «как создать обучающий, но реалистичный сценарий».

Согласование с клиентом на этой фазе защищает обе стороны: клиент контролирует, что именно будет происходить (например, может ограничить предлоги и прописать точное время отправки фишинговых писем), а исполнитель получает чёткие юридические рамки.

24. Каковы основные шаги реализации атаки в рамках методики OSINT?

Фаза реализации — это этап, на котором согласованные предлоги претворяются в жизнь.

Основные шаги:

1. **Установка и настройка ПО и инфраструктуры:**
 - учётные записи электронной почты;
 - веб-серверы;
 - документы Microsoft Office с поддержкой макросов (для доставки вредоносного кода);
 - вредоносное ПО;
 - USB-накопители и другие физические «приманки».
2. **Подготовка физического сбора данных** — при необходимости получить доступ к мусорным бакам организации, собрать документы и вывезти их за пределы площадки для анализа (метод **dumpster diving**).

3. Выполнение атак по согласованным предложениям:

- фишинговые рассылки;
- вишинговые звонки;
- другие атаки, указанные в ТЗ.

4. Использовать **только те предлоги, которые одобрило контактное лицо** со стороны заказчика.

Для этой фазы используют специализированные ОС и инструменты: **Kali Linux** (с SET — Social-Engineer Toolkit, theHarvester, Maltego, Recon-ng), форк **Trace Labs** для OSINT-расследований, либо **облачный VPS** с настроенным набором (SpiderFoot, Metasploit, Metagoofil). Использование VPS даёт независимый IP-адрес, новые экземпляры можно запускать с новыми IP, чтобы избежать обнаружения, а потом «уничтожить» машину одним действием.

Главное правило: реализация строго следует ТЗ и согласованным предложениям — отход от них создаёт юридический риск.

25. Как можно обнаружить наличие атаки в процессе её выполнения?

В контексте фреймворка социальной инженерии есть **фаза обнаружения** — на ней защитники пытаются обнаружить действия атакующего и принять меры для снижения их эффективности.

Как обнаруживается атака:

- **Сотрудники сообщают о подозрительных письмах/звонках** — это главный сигнал; считается важной метрикой;
- **Защитные системы фиксируют активность** — обнаружение фишинга почтовыми фильтрами, антивирусом, системами мониторинга;
- **Аномалии в сети** — необычное время активности, нестандартные подключения, «отстук» вредоносного кода на внешний сервер.

Важные нюансы из лекций:

- В зависимости от масштаба атаки защитники **могут знать или не знать**, что атака санкционирована. Если это работа **красной команды** (red team) — они, скорее всего, не знают заранее.
- Целевые атаки специально делаются **нетривиальными** — их сложно обнаружить защитными системами в реальном времени, потому что атакующий скрывает присутствие. Статические списки шаблонов (сигнатуры, белые списки) не ловят «нешаблонные» угрозы.
- Поэтому существует класс решений **post-breach** («после взлома»), а одним из методов своевременного обнаружения являются **ханипоты** («ловушки») — фейковые рабочие станции и аккаунты, обращение к которым выдаёт атакующего.

В целом про целенаправленную атаку из лекции: «избежать риска компрометации фактически невозможно» — поэтому нужны системы выявления уже произошедших, неизвестных атак.

Хотя фаза обнаружения «кажется менее захватывающей, чем сама атака, это самая важная часть процесса».

26. Каким образом можно измерить успешность атаки по методике OSINT?

Есть отдельная **фаза измерения**. На ней собирают метрики (показатели), которые потом войдут в отчёт для клиента.

Какие показатели измеряют:

- **Сколько людей стали жертвами ухищрений** (перешли по ссылке, ввели данные, открыли вложение);
- **Сколько времени потребовалось для обнаружения атаки** — как быстро защитники её заметили;
- **Когда жертвы сообщили об атаке** — насколько оперативно;
- **Сколько было таких сообщений** — какая доля сотрудников проявила бдительность;
- множество других показателей в зависимости от задачи.

Важно понимать: успешность измеряется **не только в пользу атакующего**. Высокая скорость обнаружения и большое число сообщений от сотрудников — это тоже «успех», но успех **защиты**. Поскольку конечная цель этичной атаки — научить организацию выявлять и смягчать атаки социальной инженерии, хорошим результатом считается, когда сотрудники быстро распознают и сообщают об угрозе.

После сбора и анализа метрик информацию **компилируют в отчёт для клиента** (см. вопрос 27). Метрики делают результат теста объективным и сравнимым: организация видит конкретные цифры, а не просто «вас можно взломать».

27. Какие шаги необходимо выполнить для подготовки отчёта об атаке по методике OSINT?

Фаза отчётности (составления отчёта) объединяет всё, что было сделано, в один документ для клиента.

Шаги подготовки отчёта:

1. **Собрать все метрики** из фазы измерения (число жертв, время обнаружения, число сообщений и т.д.).
2. **Включить ТЗ** — техническое задание, чтобы было видно, в каких рамках работал исполнитель.
3. **Добавить краткое изложение идеи и плана атаки.**
4. **Добавить краткое изложение того, как прошло взаимодействие** — ход выполнения.
5. **Включить все выводы**, полученные при сборе OSINT и выполнении задания (в том числе советы по защите).
6. **Использовать шаблон отчёта** (в методичках для этого есть приложение-шаблон).

7. Представить отчёт клиенту на проверку.

8. **Защитить документ.** Если исполнитель решает сохранить копию отчёта, её нужно обязательно защитить — содержащаяся в нём информация потенциально может быть использована для реальной атаки на клиента.

Дополнительно (из защитных практик): хороший аналитический отчёт строится по принципу **трассируемости** — каждый существенный вывод связан с источником и уровнем уверенности; в нём разделены факты, гипотезы и интерпретации; есть раздел ограничений исследования и защитно-ориентированные рекомендации.

Цель отчёта — не похвастаться находками, а показать клиенту логику и дать ему конкретные шаги для повышения безопасности.

28. Чем отличается практика pwdlogy от других методов атаки в OSINT?

pwdlogy (произносится «пэсдолоджи») — это утилита для создания **профильных словарей паролей**. Её отличие от других методов атаки:

- **pwdlogy не взламывает пароли и не атакует системы напрямую.** Она только **создаёт список возможных паролей** по заданному набору ключевых слов, дат рождения и т.д. То есть это вспомогательный, подготовительный инструмент.
- **Это «персонализированная», OSINT-ориентированная атака.** В отличие от brute-force (перебор всех комбинаций подряд) или атаки по стандартному словарю (типовые пароли), pwdlogy строит словарь **под конкретную жертву**, о которой собрана личная информация: имя, ник, хобби, любимая команда, любимая еда, дни рождения, имена питомцев, членов семьи, друзей.
- Это делает атаку гораздо более **точной и эффективной**, потому что люди часто используют в паролях именно личные данные.
- **pwdlogy работает в связке с другими инструментами:** сгенерированный словарь затем подаётся в инструменты перебора — Burp Suite, THC-Hydra, Hashcat и др.

Коротко: другие методы либо «трубые» (brute-force — перебор всего подряд), либо «общие» (словарь типовых паролей), а pwdlogy — это **OSINT-метод**: он превращает собранную об одном человеке открытую информацию в целевой словарь паролей. Сам взлом — это уже следующий шаг другими инструментами.

29. Как можно использовать утилиту crunch в ходе атаки по методике OSINT?

crunch — это **генератор словарей паролей** (списков слов, WordList). Он может создать все возможные комбинации и перестановки символов по заданным правилам.

Особенности crunch:

- генерирует списки методом комбинации и перестановки;
- может разбить вывод по количеству строк или размеру файла;
- поддерживает возобновление процесса после остановки;

- поддерживает паттерны (образцы) с числами и символами;
- поддерживает Unicode.

Синтаксис:

```
crunch <мин-длина> <макс-длина> [набор символов]
```

Пример: `crunch 3 7 abcdef` создаст все пароли длиной от 3 до 7 символов из символов "abcdef".

В паттерне (`-t`) используются спецсимволы:

- `@` — символы в нижнем регистре;
- `,` — символы в верхнем регистре;
- `%` — цифры;
- `^` — спецсимволы (всего 33).

Где применяется в атаке. WordList — один из важнейших файлов при взломе паролей. Методы взлома: словарная атака (по готовому словарю), brute-force (полный перебор), гибридная (словарь + добавление цифр/символов), слоговая, атака по правилам. crunch готовит словарь, который потом подаётся в инструмент перебора (например, sshprank, Hydra). В практических работах crunch и rwdlogu вместе используют для составления словарей логинов и паролей при подборе доступа к SSH.

Коротко: crunch не атакует сам — он **создаёт «топливо» (словарь) для атак перебора.**

30. Что представляет собой Brute-force атака и как она применяется в OSINT?

Brute-force атака («атака грубой силой», полный перебор) — это метод взлома пароля путём **перебора всех возможных комбинаций** символов.

Среди методов взлома пароля brute-force выделяется так:

- **Плюс:** если перебрать все возможные комбинации, можно говорить о **100%-й уверенности** во взломе пароля — рано или поздно правильная комбинация будет найдена.
- **Минус:** требует **огромного количества ресурсов** — вычислительных мощностей и времени. Для длинного и сложного пароля перебор может занять астрономическое время.

Для сравнения, другие методы: словарная атака (быстро, но без 100% гарантии), гибридная (словарь + цифры/символы), слоговая (комбинация brute-force и словаря), атака по правилам (когда известна часть информации о пароле).

Применение в связке с OSINT. Чистый brute-force неэффективен из-за ресурсоёмкости, поэтому на практике его «сужают» с помощью OSINT:

- OSINT собирает информацию о жертве → pwdlogy строит **целевой словарь** → перебор идёт не по всем комбинациям, а по вероятным;
- crunch генерирует ограниченные наборы по известному паттерну (если OSINT раскрыл часть структуры пароля — например, «пароль начинается с имени и заканчивается годом»).

В практических работах brute-force применяется при подборе пары логин:пароль к SSH-серверам (инструмент sshprank), где словари заранее подготовлены через pwdlogy и crunch.

Коротко: brute-force гарантирует результат, но дорог; OSINT делает его реалистичным, резко сокращая пространство перебора.

31. Какие возможности предоставляет утилита Masscan для атаки по методике OSINT?

Masscan — это **массовый сканер IP-портов**, самый быстрый сканер портов интернета.

Возможности и особенности:

- **Огромная скорость.** Отправляя до 10 миллионов пакетов в секунду, Masscan может просканировать весь интернет примерно за 6 минут. При разгоне до 25 млн пакетов/с — весь интернет (по одному порту на IP) за 3 минуты. По умолчанию скорость ограничена 100 пакетами/с (для безопасности).
- **Асинхронная передача.** Внутри работает подобно scanrand, unicornscan и ZMap, но быстрее их.
- **Результат, похожий на nmap** — создаёт вывод в формате, схожем с самым известным сканером портов.
- **Гибкость** — позволяет задавать произвольные диапазоны адресов и портов.
- **Подходит для обзора сетей большого масштаба** — таких как интернет или крупные внутренние сети.

Применение для разведки. Masscan используется на стадии сканирования: получив диапазон IP-адресов организации, его «прогоняют» через Masscan, чтобы быстро понять, какие порты открыты на периметре. Например, для сбора SSH-баннеров с диапазона /16 (65 536 адресов) хватает нескольких минут.

Связка с другими инструментами. В практических работах Masscan используется внутри утилиты **sshprank** (которая использует Python-модуль masscan): сначала Masscan быстро сканирует сеть и находит SSH-серверы, затем sshprank пытается подобрать к ним учётные данные. Masscan также поддерживает ряд опций, совместимых с nmap (`masscan --nmap`).

Коротко: Masscan — это инструмент **скоростного обнаружения** открытых портов и сервисов на больших диапазонах, первый шаг перед более детальным анализом.

32. Что такое Tor и как он может быть использован в атаке по методике OSINT?

Нужно различать три вещи с словом «Tor»:

- **Tor** — программа, которую вы запускаете на компьютере для подключения к сети Tor;
- **сеть Tor** — множество компьютеров волонтеров, которые обрабатывают и перенаправляют запросы;
- **Tor Browser** — сборка браузера Firefox + Tor + плагины и настройки для анонимности.

Как работает Tor. Трафик шифруется и проходит через цепочку из как минимум трёх узлов. Каждый узел расшифровывает только часть данных — ровно столько, чтобы узнать следующий узел. Последний узел (**выходной узел / exit relay**) расшифровывает данные и отправляет их на сайт назначения, не раскрывая исходный IP.

Для чего используется Tor:

- шифрование данных, чтобы их не анализировал интернет-провайдер или посторонние в открытом Wi-Fi;
- сокрытие своего IP-адреса от конечного веб-сайта;
- доступ к заблокированным в регионе сайтам.

Применение в OSINT-разведке. Для аналитика главная ценность Tor — **анонимность**: при изучении объекта, способного обнаружить слежку, нельзя «светить» свой настоящий IP. Через Tor исследователь:

- проводит поиск, не раскрывая своё расположение и личность;
- не попадает в «ленты угроз» (его IP не свяжут с подозрительной активностью);
- может использовать разные поисковики (DuckDuckGo в Tor) для разнообразия результатов.

Слабые места Tor: выходной узел может быть недобросовестным и собирать данные (но идентифицировать вас не сможет, если только вы не используете e-mail как логин); трафик от выходного узла до сайта без HTTPS не зашифрован. Поэтому: не ставить плагины в Tor Browser, не открывать PDF в нём, не использовать настоящую личность для регистрации, при работе с конфиденциальными делами — использовать анонимную ОС (Tails).

33. Какие методы можно использовать для определения целей атаки в рамках OSINT?

Определение целей — это и постановка задачи, и выявление конкретных объектов воздействия.

На уровне постановки задачи (с клиентом): обсудить, зачем нужно тестирование (обоснование новых средств защиты, оценка персонала, проверка соблюдения правил, оценка работы службы безопасности). Ответы не влияют на качество работы, но помогают понять, чего ожидать.

На уровне выявления конкретных целей (OSINT-разведка):

- **Поиск ключевых сотрудников** — кто принимает решения, кто имеет доступ к ценным ресурсам;
- **Определение синтаксиса корпоративной почты** (имя.фамилия@domain) — позволяет вычислить адреса конкретных людей;
- **Поиск точек входа** — серверы и панели на периметре, мобильные устройства сотрудников, облачные аккаунты;
- **Получение диапазона IP-адресов** организации (включая IP подрядчиков и провайдеров — атакующий их тоже включит в «скоп»);
- **Сканирование** — Nmap, Masscan, Shodan для определения, что доступно из интернета;
- **Анализ соцсетей** — поиск сотрудников с общими интересами, удобными для предложения;
- **Поиск эксплуатабельных ресурсов** — публичные веб-приложения, забытые сервисы, непатченные системы.

Приоритет часто отдаётся **эксплуатабельным точкам входа на периметре**, потому что облачные аккаунты сотрудников требуют «интерактива» с жертвой (фишинговой коммуникации), что повышает риск обнаружения.

Коротко: цели определяются через сочетание сбора OSINT (кто и что доступно) и оценки стоимости/риска использования каждого вектора.

34. Что такое pwdlogy?

pwdlogy — это утилита (программа) для создания **профильных словарей паролей** под конкретную жертву.

Суть: pwdlogy помогает создать файл с возможными паролями для одного человека, о котором собрана как можно более полная личная информация.

Что важно понимать:

- **pwdlogy не взламывает пароли.** Взлом паролей «не так прост, как создание словаря». pwdlogy только **генерирует список возможных паролей** по заданному набору ключевых слов, дат рождения и т.д.
- Это **OSINT-инструмент**: его «топливо» — открытая информация о человеке (имя, ник, хобби, любимая команда, любимая еда, дни рождения, имена питомцев, родственников, друзей). Логика проста: люди часто вставляют эти данные в свои пароли.
- pwdlogy используется **в связке** с инструментами перебора: Burp Suite, THC-Hydra, Hashcat и др. Сначала pwdlogy создаёт словарь, потом другой инструмент перебирает пароли по нему.

Как устанавливается и запускается: клонируется из репозитория (`git clone https://github.com/tch1001/pwdlogy`), запускается от пользователя в группе sudo. Подробнее о параметрах — в следующем вопросе.

Коротко: `pwdlogy` — это «фабрика персональных словарей паролей»: превращает то, что OSINT нашёл о человеке, в список вероятных паролей именно этого человека.

35. Какие параметры можно использовать при работе с утилитой `pwdlogy`?

Работа с `pwdlogy` строится вокруг нескольких входных файлов и команд.

Подготовка входных данных (что собрать о жертве):

- узнать имя, ник, хобби, любимую спортивную команду, любимую еду — всё, что может попасть в пароли;
- собрать дни рождения, имена домашних питомцев, имена членов семьи и друзей.

Входные файлы:

- `keywords.txt` — сюда помещаются все ключевые слова, которые, по вашему мнению, пригодятся для формирования словаря;
- `commonPhrases.txt` — сюда добавляются ключевые фразы;
- `birthday.txt` — сюда вписывается вся информация о днях рождения и других важных датах (в файле есть пример формата записи).

Команды управления:

- `start` — запустить генерацию словаря. Сгенерированный словарь будет называться `gen.txt` и появится в папке с программой;
- `help` — посмотреть дополнительные настройки и параметры.

Порядок работы: заполнить `keywords.txt`, `commonPhrases.txt` и `birthday.txt` → запустить `pwdlogy` (от пользователя в группе `sudo`) → выполнить команду `start` → дождаться завершения → забрать `gen.txt`. Для просмотра дополнительных настроек — команда `help`.

Коротко: главные «параметры» `pwdlogy` — это три файла-источника (ключевые слова, фразы, даты) и две команды (`start` и `help`); результат — файл `gen.txt`.

36. Какие инструменты можно использовать для анализа утечек паролей?

Утечка данных (data breach) — это преднамеренное или непреднамеренное обнародование конфиденциальной информации, часто из-за хакерских атак или недовольных сотрудников. Утечки могут включать e-mail, логины и пароли, данные карт, медицинскую и финансовую информацию.

Инструменты и подходы для работы с утечками паролей и аккаунтов (из лекций):

- **Поиск по e-mail:** Emailsherlock, Emailrep.io — находят, на каких сайтах зарегистрированы аккаунты с определённой почтой;
- **Поиск по никнейму:** WhatsMyName (по 280+ сервисам), Usersearch.org (включая тематические форумы), Instant Username Search, Checkuser, Namechekup, SuIPbiz;

- **Maigret / Sherlock** — собирают «досье» на человека по имени пользователя, проверяя 2300+ сайтов, без API-ключей;
- **Email2phonenumber** — собирает данные со страниц восстановления аккаунта и находит номер телефона;
- **Databases (databases.today)** — каталог общедоступных баз данных для исследователей безопасности и журналистов;
- **GitHub Dorks** — поиск конфиденциальных данных (приватные ключи, учётные данные, токены) в репозиториях;
- **Официальные репозитории утечек** — WikiLeaks, Cryptome, Offshore Leaks.

Важная этическая и правовая оговорка. Статус утечек спорный. Один взгляд: утечка стала частью OSINT-источников. Противоположный: данные получены незаконно и не должны использоваться. Рекомендация из лекции: обращаться с утечками **осторожно, индивидуально**; если утекла личная или частная корпоративная информация — предпочтительно **не обнародовать её** и не использовать в публичной части исследования, уважая личные данные человека. Утечки из даркнета лекция прямо не публикует, так как это незаконные сайты.

37. Какие методы поиска информации существуют?

Методы поиска информации в интернете — это набор приёмов и инструментов:

- 1. Обычные поисковые системы** (Google, Bing) — отправляют сканер (crawler), который индексирует сайты в огромные базы; пользователь запрашивает индекс и получает ранжированные результаты. Здесь важен **подбор правильных ключевых слов**.
- 2. Расширенный поиск и операторы (Google Dorks)** — специальные операторы (см. вопрос про использование поисковых систем): кавычки для точной фразы, **OR**/**|**, минус для исключения, **site:**, **inurl:**, **filetype:**, **related:**, **info:**, **cache:**, **define:** и др.
- 3. Поисковые системы, ориентированные на конфиденциальность** — DuckDuckGo, Qwant, Swisscows и др. (не отслеживают пользователя).
- 4. Метапоисковые системы** — не имеют своего индекса, опрашивают несколько других поисковиков сразу (eTools, All the Internet, Carrot2).
- 5. Национальные поисковые системы** — Yandex (Россия), Baidu (Китай), Goo (Япония) и др.
- 6. Специализированные поисковики:**
 - бизнес-поиск (OpenCorporates, Crunchbase);
 - поиск по коду (Searchcode, GitHub Dorks);
 - FTP-поисковики;
 - поиск IoT-устройств (Shodan, Insecam);
 - поиск изображений и видео;
 - поиск метаданных.

7. Архивы и кэш — Wayback Machine, archive.fo (просмотр прошлых версий сайтов).

8. Серая литература — академические и научные ресурсы (Google Scholar, Academia, ScienceDirect).

9. Мониторинг изменений — Google Alerts, Visual Ping (оповещения об изменениях страниц).

10. Инструменты поиска файлов на своём компьютере — Everything, Locate32.

Главный принцип: использовать **несколько поисковых систем** — результаты сильно различаются.

38. Что такое поисковые системы, ориентированные на конфиденциальность?

Поисковые системы, ориентированные на конфиденциальность — это поисковики, которые **не отслеживают действия пользователей**: не собирают историю поиска, не привязывают запросы к личности, не строят рекламные профили.

Обычные поисковики (Google, Bing) записывают, что вы ищете, и связывают это с вашим аккаунтом и IP — это удобно для рекламы, но опасно для приватности (вся история поиска привязана к реальному имени).

Популярные приватные поисковики (из лекции):

- **DuckDuckGo** — самый известный; OSINT-исследователи обычно используют его для поиска при работе через Tor Browser;
- **Qwant** — базируется во Франции;
- **Oscobo** — базируется в Великобритании;
- **Swisscows** — приватный веб-поиск, базируется в Швейцарии;
- **Gigablast** — поисковая система с открытым исходным кодом;
- **Gibiru** — неподцензурная и анонимная поисковая система.

Зачем они нужны OSINT-аналитику:

- сохранение анонимности при проведении поиска;
- результаты не «персонализируются» под ваш профиль (вы видите «нейтральную» выдачу, а не подстроенную под вас);
- меньше риск, что ваши запросы кто-то проанализирует.

Рекомендация из лекции: перед поиском нужно анонимизировать подключение или просто использовать Tor Browser. Многие исследователи используют **несколько поисковых систем**, потому что результаты сильно различаются.

39. Какие национальные поисковые системы популярны в разных странах?

Национальные поисковые системы — это поисковики, которые особенно популярны в конкретной стране и полезны для поиска информации именно в этой стране (учитывают язык, локальные ресурсы).

Из лекции, по странам:

- **Yandex** — Россия;
- **Search.ch** — Швейцария;
- **Alleba** — Филиппины;
- **Baidu** — Китай;
- **Eniro** — Швеция;
- **Daum** (и Naver) — Южная Корея;
- **Goo** — Япония;
- **Onet** — Польша;
- **Parseek** — Иран;
- **Sapo** — Португалия;
- **Lableb** — поисковик на арабском языке.

Зачем они нужны OSINT-аналитику. Если объект исследования связан с конкретной страной, национальный поисковик часто находит локальные сайты, документы и упоминания, которые глобальные Google/Bing ранжируют ниже или вовсе пропускают. Например, для российских объектов Yandex нередко даёт более полные результаты, чем Google; для китайских — Baidu.

Также упоминается **Search Engine Colossus** — каталог поисковых систем из 317 стран и территорий мира, охватывающий все разговорные языки.

Коротко: национальные поисковики — это способ «копать вглубь» по конкретной стране и языку, дополняя глобальные поисковики.

40. Какие сайты бизнес-поиска можно использовать для поиска деловой информации?

Сайты бизнес-поиска дают информацию о компаниях по всему миру. Из лекции их две группы.

Годовые отчёты (annual reports) — документы, выдаваемые компанией акционерам раз в год; содержат бюджет, финансовое положение, прибыль, отчёты о убытках, данные об управлении и аудиторе, денежные потоки:

- **annualreports.com** — тысячи годовых отчётов;
- **reportlinker.com** — 60+ млн таблиц, цифр и наборов данных;
- **sec.gov/edgar** — Комиссия по ценным бумагам и биржам США;

- **sedar.com** — документы канадских администраторов ценных бумаг;
- реестры компаний правительства Великобритании.

Профили и каталоги корпораций — адреса, филиалы, контакты, имена сотрудников, типы услуг:

- **OpenCorporates** — крупнейшая открытая база данных компаний в мире;
- **Crunchbase** — от стартапов до Fortune 1000;
- **Corporationwiki** — поиск компании и визуализация связей между людьми в ней;
- **Zoom Info, Kompass** (60+ стран), **Infobel, Orbis directory**;
- **LittleSis** — профили 185 000 человек и 67 000 организаций, упор на влиятельных людей;
- **Companies House** — реестр предприятий Великобритании;
- **EUROPAGES, Vault, Owler, Kvk** (Голландская торговая палата);
- **International White and Yellow Pages** — имена, адреса, телефоны, факсы.

Бизнес-информация из OSINT может раскрыть прибыль, текущие и будущие проекты, бизнес-иерархию, даты компании (встречи, корпоративы, встречи с инвесторами).

41. Что такое поисковые системы метаданных?

Здесь под «поисковыми системами метаданных» понимаются **метапоисковые системы (metasearch engines)**.

Главное отличие от обычных поисковиков: метапоисковые системы **не имеют собственного индекса** (своей базы проиндексированных страниц). Вместо этого они отправляют ваш запрос **в несколько других поисковых систем сразу** (Google, Bing, Yahoo и др.) и в сторонние источники данных, получают результаты, ранжируют их и показывают вам через свой интерфейс.

При этом метапоисковик не может вмешиваться в ранг и релевантность контента, поставляемого его источниками — он лишь агрегирует чужие результаты.

Главное преимущество — способность собрать результаты из многих источников за один запрос. Это:

- мгновенно сокращает время поиска;
- даёт более полные результаты;
- обеспечивает расширенную конфиденциальность по сравнению с Google и Bing (многие метапоисковики не собирают личную информацию).

Популярные метапоисковые системы (из лекции):

- **eTools.ch** — собирает результаты крупных международных поисковиков, не собирая личную информацию;
- **All the Internet** — опрашивает основные поисковики, включая Amazon и eBay;
- **Fagan Finder** — поисковики + Q&A-сайты и блоги;

- **izito.com** — агрегирует Yahoo, Bing, Wikipedia, YouTube и др.;
- **Metacrawler** — Google + Yahoo;
- **My All Search, Carrot2** (организует результаты в тематические категории), **elocalfinder, Opentext**.

Коротко: метапоисковик — это «поисковик поисковиков», который экономит время и повышает приватность.

42. Как можно обнаружить поддельные новости с помощью OSINT?

Поддельные новости (fake news) распространяются мгновенно из-за лёгкости обмена в соцсетях; их публикуют ради коммерческой выгоды, пропаганды или дезинформации. Любая подозрительная информация не должна попадать в OSINT-исследование.

Контрольный список для проверки новости:

1. **Сначала прочитайте материал целиком.** Не верьте ничему, пока не проверите источник.
2. **Прочитайте, откуда новость** (источник).
3. **Если источник надёжный/известный** (всемирно известное информагентство) — перейдите на сайт первоисточника и проверьте, есть ли там та же информация (например, новость приписывается Reuters — зайдите на reuters.com).
4. **Если источник неизвестный** — проведите онлайн-поиск: кто ещё опубликовал ту же новость.
 - Если достоверный известный сайт опубликовал ту же историю из того же источника — скорее всего, это правда;
 - Иначе — проверяйте дальше или откажитесь от использования.
5. **Читайте контент только на авторитетных сайтах.** Менее известные сайты тщательно исследуйте, прежде чем считать их новости действительными.

Специальные сервисы фактчекинга (из лекции):

- **Snopes** — обнаруживает ложные новости, истории, городские легенды, проверяет слухи;
- **Noaxu** — отслеживает распространение ложных утверждений через соцсети;
- **FactCheck** — сотрудничает с Facebook, маркирует фейки;
- **reporterslab.org/fact-checking** — карта глобальных сайтов фактчекинга;
- **TruthOrFiction** — фейки в разных темах;
- **Verification Handbook, Verification Junkie, citizenevidence.org** (Amnesty International), **InVID Verification Plugin** (для Firefox и Chrome).

Дополнительно: поиск по изображениям помогает выявить фото из другого события или с фотостока.

43. Что такое серая литература и как её можно использовать для поиска информации?

Серая литература — это материалы, производимые **вне мира коммерческих издательских систем**. У неё два типа.

1. Собственно «серая литература» — книги, журналы и всё, что можно получить публично через традиционные каналы книжных магазинов или академических публикаций.

Пользователь обычно платит абонентскую плату или покупает напрямую. Пример канала — **Springer** (миллионы научных документов: журналы, книги, протоколы).

2. «Серая информация» — то, что **нельзя легко получить через обычные книжные магазины**; у неё есть специализированные каналы, часть — через подписные агентства. Сюда входят: академические работы, препринты, разбирательства, конференц-документы, отчёты об исследованиях, маркетинговые отчёты, технические стандарты, диссертации, тезисы, торговые публикации, меморандумы, правительственные отчёты, переводы, информационные бюллетени, обзоры рынка, черновики книг и статей.

Как использовать в OSINT. Серая литература даёт доступ к специализированным сведениям, которых нет в обычной поисковой выдаче. Полезные ресурсы (из лекции):

- **Academia.edu** — платформа учёных, 19+ млн работ;
- **Google Scholar** — научный поиск, ранжирование по числу цитирований;
- **ScienceDirect** — 250 000+ статей открытого доступа;
- **CERN Document Server, SSRN, BASE** (Bielefeld Academic Search Engine, 100+ млн документов);
- **Academic Torrents** — наборы данных и научные работы через торренты;
- **American Doctoral Dissertations, PQDT Open** — диссертации;
- **Databases (databases.today)** — каталог общедоступных баз данных.

Коротко: серая литература — это «глубокий» слой информации (наука, отчёты, диссертации), полезный, когда обычного веб-поиска недостаточно.

44. Как можно найти информацию об утечке данных с помощью OSINT?

Утечка данных — преднамеренное или непреднамеренное обнародование конфиденциальной информации. Происходит в основном из-за хакерских атак или недовольных сотрудников. Может включать: данные карт, персональные данные (ПД), медицинскую и финансовую информацию, логины/пароли, коммерческую тайну, планы корпораций, интеллектуальную собственность.

Где и как искать информацию об утечках:

- **Признаки утечки через поисковые системы** — поиск по e-mail и никнеймам показывает, где «всплыли» аккаунты (Emailsherlock, Emailrep.io, WhatsMyName, Maigret);

- **Официальные репозитории утечек:** WikiLeaks, Cryptome, Offshore Leaks — публикуют утечки официальных документов (в основном военных, разведывательных);
- **Databases (databases.today)** — каталог общедоступных баз для исследователей безопасности и журналистов;
- **GitHub Dorks** — поиск утёкших ключей, учётных данных и токенов в репозиториях;
- утечка личной, финансовой и корпоративной информации может находиться в **даркнете**, но лекция прямо отмечает, что не публикует такие ссылки, так как это незаконные сайты.

Правовой статус — спорный. Один взгляд: утечка стала частью OSINT-источников, и с ней можно обращаться как с общедоступной информацией. Противоположный: данные получены незаконно (нарушением системы или правовых норм) и не должны использоваться в OSINT.

Рекомендация из лекции. OSINT-исследование не может игнорировать существование утечек (особенно при расследовании утечки разведданных), но обращаться с ними нужно **осторожно и индивидуально**. Если утекла личная или частная корпоративная информация — предпочтительно **не обнародовать её**, отказаться от неё в публичной части и использовать только полезные элементы, уважая личные данные человека, которые уже один раз просочились.

45. Какие инструменты поиска файлов существуют?

Здесь речь о двух вещах: поиск файлов **в интернете** и поиск файлов **на своём компьютере**.

Поиск файлов в интернете:

- **FTP-поисковики.** FTP (File Transfer Protocol) — старый протокол передачи файлов. Многие FTP-серверы оставлены без пароля (анонимный доступ): из 13+ млн FTP-серверов около 1,1 млн позволяют анонимный доступ. Инструменты: Global file search, Filemare, Archie. Google-запросы для FTP: `inurl:"ftp://www." "Index of /"`.
- **Google Dorks** — оператор `filetype:` (например, `filetype:pdf`) для поиска документов определённого типа.
- **Архивы** — Wayback Machine для поиска старых версий и файлов.

Поиск файлов на своём компьютере. Встроенный поиск ОС медленный и без расширенных функций. Идея специальных инструментов — создать **индекс** (базу имён файлов и их расположения), и искать по индексу, а не «вручную» по диску. Инструменты (из лекции):

- **Locate32** — создаёт файл базы данных с именами всех файлов/папок и их расположением;
- **Everything (voidtools)** — крошечная программа, потребляет мало ресурсов, индексирует 1 000 000 файлов за минуту, поддерживает Boolean, regex, подстановочные знаки, поиск по содержимому;
- **FileSeek** — многопоточный поиск, синхронизация результатов между компьютерами, поиск по содержимому через regex;
- **Open Semantic Search** — поисковая система с открытым кодом и инструментами для исследований; подходит группам, анализирующим большие наборы документов и новости.

Возможность быстро находить файлы в собранном массиве — неотъемлемая часть навыков OSINT-аналитика.

46. Какие критерии выбора поисковой системы для OSINT следует учитывать?

Выбор поисковика влияет на полноту, объективность и безопасность исследования. Критерии (по совокупности лекций):

- **Конфиденциальность / отслеживание.** Отслеживает ли поисковик пользователя. Для работы с чувствительными данными выбирают приватные поисковики (DuckDuckGo, Qwant, Swisscows), не привязывающие запросы к личности.
- **Персонализация выдачи.** Обычные поисковики «подстраивают» результаты под профиль пользователя — это искажает картину. Приватные поисковики дают более нейтральную выдачу.
- **Охват и тип индекса.** Свой индекс (Google, Bing) или метапоиск (агрегирует много источников — eTools, Carrot2). Метапоиск даёт более полные результаты за один запрос.
- **Поддержка расширенных операторов (dorks).** Google силён большим набором операторов для точного поиска.
- **География и язык.** Для объекта из конкретной страны нужен национальный поисковик (Yandex, Baidu, Goo).
- **Специализация.** Нужен ли поиск по коду, по устройствам IoT, по бизнесу, по изображениям, по FTP — для этого есть отдельные специализированные поисковики.
- **Архивность.** Нужна ли история сайтов — тогда Wayback Machine, archive.fo.

Главная рекомендация из лекции: не полагаться на один поисковик. «Вы будете удивлены разнообразием результатов» при использовании разных поисковых систем для одного и того же запроса. И **перед любым поиском нужно анонимизировать подключение** (или использовать Tor Browser).

47. Какие преимущества использования поисковых систем, ориентированных на конфиденциальность?

Преимущества приватных поисковиков (DuckDuckGo, Qwant, Oscobo, Swisscows, Gigablast, Gibiru):

- **Не отслеживают действия пользователя** — не сохраняют историю поиска, не строят рекламный профиль. Обычные поисковики хранят историю и привязывают её к реальному имени аккаунта — «хранение таких журналов опасно».
- **Анонимность исследования.** OSINT-аналитику критически важно не «светиться»: приватные поисковики не связывают запросы с личностью. DuckDuckGo обычно используют для поиска при работе через Tor Browser.
- **Нейтральная, неперсонализированная выдача.** Обычные поисковики подстраивают результаты под ваш профиль (пузырь фильтров). Приватный поисковик

показывает более объективную картину — это важно, чтобы не упустить релевантные результаты.

- **Меньше риск анализа ваших запросов** третьими лицами.
- **Часть из них с открытым исходным кодом** (Gigablast) — логику работы можно проверить.
- **Снижение цифрового следа.** Меньше данных о вас оседает у поисковика — меньше материала для слежки и профилирования.

Дополнительно с приватными поисковиками удобно сочетать **метапоисковые системы** — они тоже обычно не собирают личную информацию и при этом дают более полные результаты.

Коротко: приватные поисковики защищают и **анонимность аналитика**, и **объективность результатов** — оба фактора критичны для качественного и безопасного OSINT.

48. Какие опасности могут возникнуть при использовании популярных национальных поисковых систем?

Опасности при использовании популярных национальных поисковиков (Yandex, Baidu и др.) вытекают из общих рисков обычных, отслеживающих поисковиков:

- **Отслеживание и логирование запросов.** Национальные поисковики, как и Google, обычно записывают, что вы ищете, ваш IP, время. Эта информация привязывается к вашему профилю и может быть передана — в том числе государственным органам страны, где базируется поисковик.
- **Раскрытие интереса к объекту.** Для OSINT-аналитика опасно «засветить» интерес к конкретному объекту: история поиска связывается с реальной личностью. Это снижает анонимность исследования.
- **Юрисдикция и законодательство страны.** Национальный поисковик подчиняется законам своей страны (по защите данных, по раскрытию информации правоохранителям). Например, в России закон 152-ФЗ требует хранить персональные данные граждан в базах на территории РФ; за нарушение — блокировка сайтов через Роскомнадзор.
- **Персонализация и цензура выдачи.** Результаты могут быть подстроены под профиль пользователя или подвергаться локальной цензуре — это искажает картину и может скрыть релевантные результаты.
- **Профилирование для рекламы.** Запросы используются для построения рекламного профиля.

Как снижать риски: перед поиском анонимизировать подключение (Tor, VPN), использовать приватные поисковики для чувствительных запросов, не входить в аккаунт при поиске, использовать несколько поисковиков. При этом национальный поисковик всё равно остаётся полезным — просто использовать его нужно с теми же предосторожностями, что и любой отслеживающий поисковик.

49. Какие основные виды бизнес-информации можно найти с помощью сайтов бизнес-поиска?

Бизнес-поиск важен для любого онлайн-расследования; собранная бизнес-информация может раскрыть многое.

Основные виды бизнес-информации:

- **Финансовое состояние** — прибыль, бюджет, финансовое положение, отчёты о убытках, денежные потоки (из годовых отчётов);
- **Текущие и будущие проекты** компании;
- **Бизнес-иерархия** — структура управления, кто чем руководит;
- **Имена сотрудников** — в том числе их бизнес-телефоны и e-mail (профили и каталоги);
- **Даты компании** — ежегодные встречи, корпоративные праздники, встречи с инвесторами;
- **Адреса, местоположение, филиалы, контактные данные;**
- **Типы услуг или отрасль**, общее описание отрасли;
- **Данные об управлении и аудиторе;**
- **Юридическая история** компании, партнёрские соглашения, негативные упоминания (через архивы новостей);
- **Связи между людьми** в компании (Corporationwiki визуализирует эти связи);
- **Отзывы и рейтинги сотрудников** (Vault).

Зачем это нужно. Бизнес-информация из OSINT полезна, например, чтобы выяснить, была ли конкретная компания или лицо частью дела об уклонении от уплаты налогов; чтобы корпорация получила глубокое представление о конкуренте. Сейчас предприятия в значительной степени полагаются на OSINT для принятия решений и прогнозирования будущих событий.

Источники: годовые отчёты (annualreports.com, SEC EDGAR), профили и каталоги (OpenCorporates, Crunchbase, Companies House, LittleSis, Kompass и др.).

50. Какие типы метаданных могут содержаться в информации, найденной с помощью поисковых систем?

Метаданные — это «данные о данных»: описательная, как правило **скрытая** информация о файле. Концептуально метаданные могут содержать все типы цифровых файлов.

Общие типы метаданных (в документах, фото, аудио, видео): имя автора, размер файла, местоположение, дата и время создания/редактирования, комментарии, ключевые слова, название темы, приложение-создатель, количество страниц, модели принтеров, ПО на компьютере.

Конкретные форматы метаданных изображений:

- **EXIF** (Exchangeable Image File Format) — стандарт тегов цифровых камер и смартфонов; встраивается в файл и работает с JPEG. Может содержать **геолокацию (GPS)** плюс широкий спектр технической информации (камера, дата, настройки съёмки);

- **XMP** (eXtensible Metadata Platform) — расширяемая платформа метаданных, поддерживает разные типы файлов, не ограничивается изображениями;
- **IPTC** — старый формат метаинформации, использовался прессой;
- ExifTool дополнительно поддерживает: GPS, JFIF, GeoTIFF, ICC Profile, Photoshop IRB, FlashPix, AFCP, ID3.

Где ещё есть метаданные: в PDF, файлах Microsoft Office, аудио (Mp3tag), видео (MediaInfo).

Зачем это OSINT-аналитику. Метаданные позволяют уточнить дату создания документа, имена пользователей, ПО, иногда геолокацию — и часто помогают **отличить реальный документ от фейкового**. Файлы Microsoft Office и PDF могут содержать большое количество метаданных, из которых в обычных «свойствах» видна лишь малая часть; для полного анализа используют MetaExtractor, ExifTool, FOCA.

С точки зрения защиты: перед публикацией файла метаданные рекомендуется удалять, чтобы не «слить» геолокацию и сведения об устройстве.

51. Какую роль играет серая литература в поиске информации для OSINT?

Серая литература (см. вопрос 43) — это материалы вне коммерческих издательских систем: научные работы, отчёты, диссертации, стандарты, конференц-документы и т.д.

Роль серой литературы в OSINT:

- **Доступ к специализированным, «глубоким» сведениям**, которых нет в обычной поисковой выдаче поверхностного веба. Обычный веб-поиск даёт верхний слой информации; серая литература — слой профессиональных и научных знаний.
- **Технические и научные детали** — стандарты, технические характеристики, отчёты об исследованиях, препринты. Это полезно, например, при реконструкции встроенного ПО, изучении технологий.
- **Аналитика рынков и отраслей** — маркетинговые отчёты, обзоры рынка, торговые публикации помогают изучить отрасль и конкурентов.
- **Правительственные документы и отчёты**, не опубликованные на коммерческой основе.
- **Источник для проверки достоверности** — академические публикации ранжируются по числу цитирований и достоверности (Google Scholar), что помогает оценить надёжность информации.

Ресурсы серой литературы для OSINT: Academia, Google Scholar, ScienceDirect, BASE, SSRN, CERN Document Server, Academic Torrents, диссертационные базы, Databases (databases.today).

Коротко: серая литература расширяет «информационную воронку» OSINT в сторону профессиональных, научных и отраслевых знаний — туда, куда обычный поиск не дотягивается; она ценна и как источник содержания, и как способ повысить достоверность выводов.

52. Какие признаки утечки данных можно обнаружить с помощью поисковых систем?

С помощью поисковых систем и связанных сервисов можно обнаружить такие признаки утечки данных:

- **Появление аккаунтов и e-mail в неожиданных местах.** Поиск по e-mail (Emailsherlock, Emailrep.io) показывает, на каких сайтах зарегистрирована почта — если e-mail «всплывает» там, где пользователь не регистрировался, это признак компрометации или продажи базы.
- **«Засветка» никнейма** на множестве сервисов (WhatsMyName, Maigret) — может указывать, что данные о пользователе агрегированы или утекли.
- **Упоминание организации/домена в репозиториях утечек** — WikiLeaks, Cryptome, Offshore Leaks, каталоги вроде Databases.
- **Утёкшие ключи, токены, учётные данные в репозиториях** — обнаруживаются GitHub Dorks (поиск частных ключей, паролей, маркеров аутентификации в публичных репозиториях).
- **Открытые FTP-серверы** с анонимным доступом — на них могут лежать налоговые документы, криптографические секреты, личные файлы (поиск FTP-дорками `inurl:ftp`).
- **Непубличная документация в открытом доступе** — документы, не предназначенные для всеобщего сведения, оказавшиеся проиндексированными из-за небрежного хранения (например, в открытых папках Google Docs).
- **Старые/архивные версии страниц** (Wayback Machine), где сохранились данные, которые уже должны были быть скрыты.

Важная оговорка. Обнаружив признаки утечки персональных или частных корпоративных данных, OSINT-аналитик должен действовать осторожно: фиксировать сам факт публикации, но не обнародовать чувствительные детали и не использовать их «удобно для злоупотребления». Защитная задача — указать организации на утечку, а не эксплуатировать её.

53. Какие основные методы поиска информации в интернете вы бы использовали для поиска конфиденциальной информации?

Под «конфиденциальной информацией» здесь понимается информация, которая чувствительна, но всё же находится в открытом доступе (например, из-за человеческого фактора). Методы её поиска **законными и пассивными средствами**:

1. **Google Dorks (продвинутые операторы).** `filetype:` (например, `filetype:xls`, `filetype:pdf`) — для документов; `inurl:`, `intitle:` — для служебных страниц; `site:` — ограничить поиск доменом; кавычки — точная фраза. Так находят непубличную документацию, случайно попавшую в индекс.
2. **Поиск по e-mail и никнеймам** — Emailsherlock, WhatsMyName, Maigret — для сбора связанных аккаунтов.

3. **Поиск метаданных** — MetaExtractor, ExifTool, FOCA — извлечение скрытых данных из документов и фото (авторы, ПО, геолокация).
4. **Shodan** — поиск открытых сервисов, устройств, веб-приложений на периметре (только просмотр, без взаимодействия).
5. **FTP-поисковики** — поиск открытых FTP-серверов с анонимным доступом.
6. **Архивы и кэш** — Wayback Machine, Cached pages — поиск удалённой или изменённой информации.
7. **GitHub Dorks** — поиск конфиденциальных данных в публичных репозиториях.
8. **Серая литература** — для специализированных и отраслевых сведений.
9. **Несколько поисковиков сразу** (включая национальные и метапоисковые) — результаты сильно различаются.

Обязательные условия (этика и безопасность):

- работать **только пассивно** — никакого сканирования, перебора, попыток входа, обхода ограничений;
- **анонимизировать подключение** (Tor/VPN) перед поиском;
- если найдены явно непубличные/чувствительные материалы (учётные данные, дампы) — **не углубляться, не копировать, не распространять**, зафиксировать только факт;
- учитывать законодательство (149-ФЗ, 152-ФЗ).

54. Какие поисковые системы, ориентированные на конфиденциальность, вы бы выбрали для работы с чувствительными данными?

Для работы с чувствительными данными выбирают поисковики, которые **не отслеживают пользователя и не привязывают запросы к личности**. Из лекции это:

- **DuckDuckGo** — основной выбор; не отслеживает действия пользователя; OSINT-исследователи обычно используют его для поиска при работе через Tor Browser. Универсальный, удобный, проверенный вариант.
- **Qwant** — базируется во Франции; альтернатива для более «европейской» выдачи.
- **Swisscows** — приватный веб-поиск, базируется в Швейцарии (страна со строгим отношением к приватности).
- **Oscobo** — базируется в Великобритании.
- **Gigablast** — поисковая система с **открытым исходным кодом** (логику работы можно проверить).
- **Gibiru** — неподцензурная и анонимная поисковая система.

Как выстроить работу с чувствительными данными (рекомендации из лекций):

1. **Сначала анонимизировать подключение** — использовать Tor Browser (или VPN), при особо чувствительных задачах — анонимную ОС (Tails).
2. **Использовать приватный поисковик** (DuckDuckGo в Tor — связка по умолчанию).

3. **Использовать несколько поисковиков и метапоисковики** — результаты сильно различаются, метапоисковики (eTools, Carrot2) тоже обычно не собирают личную информацию.
4. **Не входить в личные аккаунты** во время поиска.
5. Для регистрации на сервисах при необходимости — **не использовать настоящую личность**, иметь отдельный e-mail.

Главный выбор по умолчанию: **DuckDuckGo через Tor Browser** — это закрывает и приватность поисковика, и анонимность подключения.

55. Что такое доменная и сетевая инфраструктура организации в контексте OSINT и какие открытые источники используются для её изучения?

Доменная и сетевая инфраструктура организации в контексте OSINT — это совокупность **публично наблюдаемых** доменных и сетевых элементов, по которым можно описать цифровое присутствие объекта:

- **доменные элементы:** основной домен, связанные домены (брендовые, продуктовые, региональные, event-домены, домены документации/поддержки/вакансий), публично наблюдаемые поддомены;
- **сетевые элементы:** признаки хостинга, облачной модели, CDN, автономных систем, маршрутизации;
- **сервисные элементы:** DNS-, почтовые и сертификатные признаки.

Важно: в OSINT изучается именно **публично наблюдаемая** инфраструктура — то, что видно снаружи без вмешательства, а не внутреннее устройство сети.

Открытые источники для изучения:

- официальный сайт и его служебные разделы: «О компании», «Контакты», «Поддержка», «Вакансии», «Документация», «Пресс-центр», «Партнёрам»;
- пользовательское соглашение, политика конфиденциальности;
- публичные документы (PDF, презентации, регламенты), пресс-релизы;
- вакансии на сайте и кадровых площадках;
- архивные версии страниц (Wayback Machine);
- **общедоступные DNS-сведения** (NS-, MX-, TXT/SPF/DMARC/DKIM-записи) через публичные сервисы;
- **открытые сертификатные журналы** (Certificate Transparency) — сопоставление доменов и имён хостов;
- общедоступные сведения о маршрутизации и автономных системах (AS);
- упоминания в связанных официальных сервисах.

Всё это собирается **только пассивно и правомерно** (см. вопрос 56).

56. Чем отличается пассивный анализ от активного технического воздействия при проведении OSINT?

Это ключевое различие, определяющее **законность** OSINT-работы.

Пассивный анализ:

- работа только с информацией, которая **уже опубликована** в открытом доступе;
- **отсутствие прямого вмешательства** в инфраструктуру объекта;
- примеры: чтение сайтов и документов, просмотр архивных страниц, анализ публичных DNS- и сертификатных сведений через сторонние сервисы, изучение вакансий и публикаций;
- **законно**, не создаёт нагрузки на объект, объект обычно даже не знает о наблюдении.

Активное техническое воздействие:

- действия, которые **напрямую обращаются к инфраструктуре** объекта и/или создают на неё нагрузку;
- примеры: сетевое сканирование хостов и портов, активный перебор (брутфорс) поддоменов и имён, fuzzing, попытки входа в закрытые разделы, обход ограничений доступа, эксплуатация уязвимостей, массовые автоматизированные обращения;
- **выходит за рамки пассивного OSINT**; без разрешения часто **незаконно** и квалифицируется как тестирование на проникновение или попытка взлома.

Граница простая: **пассивный анализ — это «смотрю на то, что и так открыто»**; **активное воздействие — это «обращаюсь к самой системе объекта»**. Учебные практические работы по OSINT выполняются **строго пассивными методами**: даже просмотр DNS- и сертификатных сведений допустим только через общедоступные сервисы, без активного воздействия на сам объект.

57. Какие типы открытых публикаций несут инфраструктурные риски для организации?

Потенциально рискованная публикация — это публикация, которая сообщает о цифровой инфраструктуре **больше, чем нужно** для нормальной публичной коммуникации, и тем самым повышает информированность внешнего наблюдателя об устройстве, ролях, процессах или технологиях организации.

Типы таких публикаций:

- **Вакансии** с избыточным перечислением внутренних технологий, платформ, административных сервисов, стека (упоминания DevOps/DevSecOps, SOC, конкретных систем);
- **Скриншоты интерфейсов**, из которых читаются адреса, домены, имена хостов, шаблоны учётных записей, версии программ, элементы схемы сети;

- **Презентации, инструкции, пользовательские памятки, регламенты**, опубликованные на открытых сайтах;
- **Страницы поддержки и документации**, которые непреднамеренно раскрывают структуру внутренних или служебных сервисов;
- **Публичные кейсы внедрения, статьи, интервью**, где подробно перечислены продукты, поставщики, архитектурные решения, маршруты взаимодействия;
- **Архивные версии страниц**, где сохраняются устаревшие, но полезные для внешнего наблюдателя сведения;
- **Открытые репозитории, примеры кода, технические заметки** с инфраструктурными деталями;
- **Слайды о миграции в облако, публичные заметки о служебных маршрутах.**

Ключевая идея: **один артефакт редко опасен сам по себе**, но в сочетании с другими публикациями он складывается в целостную картину ролей, сервисов, поставщиков и контуров взаимодействия. Чем больше взаимосвязанных деталей раскрыто (названия сервисов, роли, адресные шаблоны, схемы), тем выше совокупный риск.

58. Как строится пассивный маршрут исследования в OSINT и как классифицируются технические следы для формулирования доказательных выводов и защитных рекомендаций?

Пассивный маршрут исследования — это последовательность шагов, выполняемых **только пассивными методами** (см. вопрос 56). Типовой маршрут:

1. **Паспорт объекта** — зафиксировать объект, основной предполагаемый домен, цель, гипотезы.
2. **Определение публичного цифрового контура** — официальный сайт, публичные сервисы, открытые площадки.
3. **Реестр источников** — перечислить категории источников (сайт, вакансии, документы, презентации, архив, блог, репозитории) с пометкой их типа (официальный/вторичный/архивный).
4. **Выявление технических следов** — фиксировать только то, что наблюдается пассивно.
5. **Классификация следов** (см. ниже).
6. **Поиск рискованных публикаций и оценка их риска.**
7. **Исторический анализ** — архивные версии страниц, старые документы.
8. **Корреляция** — сопоставление следов и публикаций в целостную картину.
9. **Выводы и ограничения** — с разделением по уровням уверенности.

Классификация технических следов (категории): **доменные** (домены, поддомены, архивные домены), **почтовые/контактные** (адреса e-mail, формы, шаблоны), **инфраструктурные/архитектурные** (сервисы входа, документации, API, help-центр, облачные контуры, CDN), **организационно-ролевые** (роли, команды, практики из вакансий), **документальные, визуальные** (скриншоты), **исторические**. Для каждого следа

указывают **источник** и **уровень уверенности** (подтверждено несколькими источниками / одним / требует проверки).

Доказательные выводы опираются на классифицированные следы с указанием оснований и уровней уверенности; **защитные рекомендации** формулируются нейтрально (сократить детализацию публикаций, убрать устаревшие материалы, ввести правила согласования) — без раскрытия чувствительных деталей и без оценки «объект уязвим».

59. Что понимается под публичным цифровым контуром организации в контексте OSINT?

Публичный цифровой контур организации — это совокупность **публично наблюдаемых** доменных, сервисных, публикационных, кадровых, документационных и исторических следов, которые позволяют описать:

- как объект представлен в цифровой среде;
- какие функции вынесены в отдельные контуры;
- какие внешние зависимости просматриваются;
- как это отражает организационную и технологическую структуру.

Ключевая мысль: цифровой контур нельзя свести к одному веб-сайту. Он включает в себя:

- основной сайт;
- контуры поддержки (help, support);
- документации (docs);
- вакансий (careers);
- аутентификации (auth, личный кабинет, SSO);
- медийных публикаций, блогов, новостей;
- маркетинговых площадок, лендингов;
- разработческих разделов (developer, API);
- следы внешних сервисов и платформ;
- исторические элементы (старые домены, прежние названия сервисов).

Главный исследовательский переход в анализе цифрового контура — **от набора открытых следов к аналитической модели**. Задача не перечислить находки, а объяснить, как они соотносятся между собой и что позволяют сказать об объекте. Итог — не каталог ссылок, а **карта цифрового контура** с поясняющим отчётом.

Важно отделять сам объект (организацию как юрлицо) от его **цифровых проявлений**: исследуется именно публичное цифровое присутствие.

60. Какие типы открытых источников пригодны для реконструкции цифрового присутствия объекта?

Для реконструкции цифрового присутствия используют несколько классов открытых источников (они должны анализироваться **совместно**):

- **Доменные и сервисные источники:** официальный сайт, зеркала, региональные версии, поддомены (авторизации, поддержки, документации, API, статического контента, блога, новостей, личного кабинета); публичные DNS- и сертификатные сведения.
- **Документационные источники:** документы, презентации, help-ресурсы, FAQ, пользовательские соглашения, политики конфиденциальности, пресс-релизы, регламенты, тендерные материалы. Часто дают больше информации о функциональных контурах, чем сам главный сайт.
- **Кадровые и организационные источники:** страницы вакансий, профили ролей, карьерные разделы. Показывают наличие отдельных команд, процессов поддержки, аналитики, разработки, эксплуатации, ИБ.
- **Публикационные и медийные источники:** блоги, новости, пресс-центр, публичные презентации, кейсы внедрения, статьи, интервью, видеозаписи вебинаров, страницы в соцсетях.
- **Технические/сервисные признаки:** адреса документации, контуры поддержки, сервисы входа, домены статического контента, внешние платформы доставки материалов, признаки облачных и CDN-провайдеров.
- **Исторические источники:** архивные версии страниц (Wayback Machine), старые документы, прежние пресс-релизы — для отслеживания эволюции контура.
- **Открытые репозитории и примеры кода,** если принадлежат объекту и доступны публично.

Все они дают разные «срезы» цифрового присутствия — поэтому ценность появляется именно при их **совместном анализе и корреляции**.

61. Почему доменная структура, документы, вакансии, публикации и технические следы должны анализироваться совместно?

Потому что **каждый класс источников по отдельности даёт лишь фрагмент картины**, а целостное понимание возникает только при их **корреляции**.

Конкретные причины:

- **Один источник недостаточен и может ошибаться.** Опора на один источник без перепроверки — типовая ошибка. Связь или вывод должны подтверждаться несколькими независимыми источниками.
- **Разные источники раскрывают разные стороны объекта.** Доменная структура показывает «скелет» цифрового присутствия; документы и help-ресурсы — функциональные контуры и пользовательские пути; вакансии — организационную и технологическую структуру, наличие команд и процессов; публикации — поставщиков,

события, изменения; технические следы — сервисные контуры. Ни один из них в одиночку не описывает объект полностью.

- **Один технический или сервисный признак редко достаточен для вывода.** Значимость появляется при **совокупности нескольких подтверждений**. Поэтому нужно стремиться к корреляции, а не к опоре на одиночные наблюдения.
- **Совпадение — это ещё не связь.** Если название встречается на двух страницах, это не доказывает устойчивую связь. Связь нуждается в основании: прямое указание, повторяющийся индикатор, общий контекст, несколько независимых подтверждений.
- **Перекрёстная проверка повышает уровень уверенности.** Когда вывод подтверждается доменной структурой, документом и вакансией одновременно — он становится «подтверждённым», а не «вероятным».

Коротко: совместный анализ превращает разрозненные следы в **доказательную аналитическую модель** и защищает от ошибочных, недоказанных выводов.

62. В чём состоят ограничения интерпретации открытых сведений?

Ограничения интерпретации открытых данных в OSINT:

- **Неполнота открытых данных.** В открытом доступе есть лишь часть информации об объекте; многое скрыто или вообще не публикуется. Картина по определению фрагментарна.
- **Изменение инфраструктуры во времени.** Цифровой контур меняется: домены, разделы, сервисы появляются и исчезают. Сведения быстро устаревают.
- **Смешение актуальных и исторических следов.** Архивные данные могут давать ложное представление о текущем состоянии объекта; их нельзя автоматически переносить на настоящее.
- **Совпадение ≠ связь.** Повторяющееся название или индикатор сами по себе не доказывают устойчивую связь — нужно основание.
- **Косвенность многих признаков.** Часть выводов основана на косвенных признаках (похожая лексика, общий сервисный паттерн) — такие связи лишь вероятны.
- **Возможная дезинформация.** Объект может намеренно публиковать ложную или вводящую в заблуждение информацию (активная дезинформация / OpSec).
- **Невозможность активной проверки.** Пассивный анализ не включает техническую проверку — часть гипотез так и остаётся непроверенной.
- **Риск чрезмерно сильных выводов.** Нельзя делать категоричные утверждения о внутреннем устройстве, защищённости или уязвимости объекта без достаточной доказательной базы.

Вывод: интерпретация открытых сведений требует **осторожности** — разделения подтверждённого, вероятного и требующего проверки, явного указания ограничений исследования и отказа от категоричных утверждений.

63. Какие критерии сопоставления организаций одной отрасли используются в OSINT?

При сравнительном OSINT-анализе нескольких организаций одной отрасли нужна **единая система критериев** — одинаковая для всех объектов. Рекомендуется использовать от 6 до 10 критериев. Из методички, основные критерии:

- **Централизация доменной структуры** — насколько цифровой контур сосредоточен вокруг одного домена или разбросан по многим;
- **Наличие отдельных функциональных контуров** — есть ли выделенные контуры поддержки, документации, авторизации, разработки;
- **Объём технических следов** — сколько технических артефактов наблюдается в открытом доступе;
- **Публикационная открытость** — насколько подробно объект раскрывает сведения в публикациях, вакансиях, документах;
- **Исторические доменные следы** — есть ли следы прежних доменов, ребрендинга, эволюции контура;
- **Внешние зависимости** — наблюдаемые признаки облачных, CDN-, DNS-, почтовых провайдеров и внешних платформ;
- **Наблюдаемая цифровая зрелость** — уровень централизации, согласованности и структурности цифрового присутствия.

Требования к сопоставлению:

- объекты должны быть **сопоставимы** — одной отрасли, схожего масштаба и модели цифрового присутствия (несопоставимые объекты сравнивать нельзя);
- критерии должны быть **едиными** для всех объектов и применяться по **одинаковой шкале** оценки;
- результаты сводятся в **сравнительную матрицу** (критерии по строкам, объекты по столбцам, в ячейках — наблюдения и комментарии);
- цель — увидеть **отраслевые паттерны** (что характерно для всех) и **индивидуальные различия** (что уникально).

Сравнение должно быть именно аналитическим сопоставлением, а не последовательным описанием каждого объекта по отдельности.

64. Каковы требования к доказательности и осторожности аналитического вывода при работе с открытыми данными?

Требования к доказательности и осторожности — это основа «аналитической культуры» OSINT.

Доказательность:

- **Трассируемость.** Каждое существенное утверждение должно иметь источник, уровень уверенности и объяснение. Если делается вывод — должно быть видно, какие именно

домены, документы, публикации его подтверждают.

- **Разделение фактов, гипотез и интерпретаций.** *Факт* — то, что прямо зафиксировано в источнике; *гипотеза* — предположение по совокупности признаков; *интерпретация* — объяснение значения. Эти уровни нельзя смешивать.
- **Перекрёстная проверка.** Опора на один источник недопустима; вывод тем сильнее, чем больше независимых подтверждений.
- **Воспроизводимость.** Отчёт должен показывать не только результат, но и логику — другой специалист должен суметь повторить рассуждение.
- **Матрица доказательств** — инструмент, связывающий каждый вывод с источниками и уровнем уверенности.

Осторожность:

- **Уровни уверенности.** Выводы маркируются: «подтверждено несколькими независимыми источниками» (высокий), «подтверждено одним источником / косвенными признаками» (средний), «требуется проверки» (низкий), «недостаточно данных».
- **Сила формулировки соответствует доказательной базе.** «Подтверждено» — только при нескольких подтверждениях; «зафиксировано в источнике» — при одном; «вероятно», «может указывать», «позволяет предположить» — при косвенных признаках.
- **Запрет категоричных утверждений** о внутренней архитектуре, защищённости или уязвимости объекта без достаточных оснований.
- **Явное указание ограничений исследования** (неполнота данных, изменение во времени, пассивный характер).
- Даже большое число находок **не даёт автоматически сильный вывод.**

65. Какие типы открытых технических следов имеют наибольшее значение для OSINT-анализа?

Открытый технический след — публично наблюдаемый артефакт, который помогает реконструировать цифровую инфраструктуру объекта. Из практических работ, наиболее значимые типы (категории):

- **Доменный след:** основной домен, связанные домены, поддомены, архивные/ исторические домены, публичные URL-структуры. Это «скелет» цифрового контура.
- **Контактный/почтовый след:** адреса электронной почты, шаблоны корпоративной почты (имя.фамилия@domain), формы обратной связи, служебные контакты.
- **Архитектурный/инфраструктурный след:** указания на сервис входа (auth/SSO), портал документации, API, help-центр, облачный контур, CDN, аналитические платформы, статический контент.
- **Организационно-технологический след:** упоминания ролей, команд, DevOps/DevSecOps-практик, SOC, используемых платформ — обычно из вакансий, статей, презентаций.

- **Процессный след:** публикации о релизах, мониторинге, миграции, интеграциях, поддержке, обработке инцидентов.
- **Документальный след:** структура документации, регламенты, инструкции, пользовательские соглашения.
- **Визуальный след:** скриншоты, из которых читаются адреса, имена хостов, версии ПО.
- **Исторический след:** удалённые или устаревшие публикации, старые версии домена, прежние названия сервисов.

Почему именно эти важны: доменные следы задают структуру контура; организационно-технологические раскрывают устройство команд и стек; архитектурные показывают сервисные контуры. Но **наибольшую ценность даёт не отдельный тип, а их корреляция** — связанные следы из разных категорий складываются в доказательную картину. Каждый след фиксируется с указанием источника и уровня уверенности.

66. Чем ручной поиск информации отличается от автоматизированного структурирования данных в OSINT?

Это два разных этапа работы с данными в OSINT.

Ручной поиск информации:

- цель — **найти** артефакты: исследователь сам обращается к источникам, читает, оценивает контекст, выбирает значимое;
- сильная сторона — понимание контекста, экспертная оценка значимости, гибкость;
- слабая сторона — медленно, не масштабируется, при большом объёме данных трудоёмко;
- ценность OSINT начинается не на этапе «нашёл ссылку», а позже — на этапе превращения находок в осмысленную картину.

Автоматизированное структурирование данных:

- цель — **обработать и упорядочить** уже найденные данные: очистка, удаление дублей, нормализация, выделение сущностей, тематическая разметка, классификация, присвоение уровней значимости;
- сильная сторона — скорость, масштабируемость, способность справляться с большим объёмом дублирующихся, шумовых, неоднородных следов;
- слабая сторона — не понимает контекст, допускает ошибки классификации (ложные срабатывания, неверные категории), не заменяет экспертизу.

Ключевое отличие: ручной поиск отвечает на вопрос «что есть и насколько это важно по смыслу», автоматизация — «как быстро упорядочить массив». На практике аналитик сталкивается не только с нехваткой данных, но и с **обратной проблемой** — избытком шумовых и дублирующихся следов; именно здесь нужна автоматизация.

Правильный подход — гибридный: человек вручную определяет объект, контекст и категории → автоматизирует повторяющиеся операции → вручную проверяет качество

автоматической разметки. Автоматизация — инструмент, ускоряющий обработку, но **не замена анализа**.

67. Какие операции допустимо автоматизировать в учебной защитной практике, а какие выходят за рамки пассивного и правомерного анализа?

Допустимо автоматизировать (безопасные аналитические операции над уже найденными открытыми данными):

- очистку данных и нормализацию записей (унификация регистра, написания доменов, сокращение URL);
- удаление дублей;
- выделение сущностей (доменов, e-mail, названий сервисов) из текста;
- тематическую разметку и классификацию по категориям;
- присвоение тегов, уровней аналитической значимости, признаков историчности;
- кластеризацию похожих записей по словам в заголовках/описаниях;
- подготовку сводных таблиц.

Допустимые инструменты: электронные таблицы (фильтры, сортировка, формулы, условное форматирование, удаление дублей), регулярные выражения, словари категорий, локальные блокноты/скрипты на Python или R для очистки и простой классификации, локальная полуавтоматическая разметка.

Выходит за рамки пассивного и правомерного анализа (нельзя автоматизировать):

- сетевое сканирование хостов, портов, сервисов;
- brute force, fuzzing, активный перебор поддоменов или директорий;
- обход ограничений доступа, попытки входа, использование чужих учётных записей;
- эксплуатацию уязвимостей;
- массовый сбор данных с нарушением правил площадки или с созданием значимой нагрузки на сайты;
- автоматизированную загрузку закрытых артефактов, дампов, токенов.

Главный принцип: студент автоматизирует **анализ уже найденных открытых данных**, а не «добычу данных любой ценой» и не воздействие на инфраструктуру. Автоматизация структурирует материал — она не должна превращаться в инструмент активной разведки. Любая формулировка о риске должна быть осторожной: не «объект уязвим», а «по совокупности открытых публикаций наблюдается избыточное раскрытие сведений».

68. Какие ошибки в автоматической классификации данных наиболее типичны?

При частичной автоматизации OSINT-анализа типичные ошибки автоматической классификации:

- **Ложное срабатывание.** Правило по ключевому слову относит запись не в ту категорию. Например, слово встречается в нерелевантном контексте, но правило всё равно срабатывает.
- **Неверная категория.** Запись отнесена к категории, не соответствующей её реальному смыслу.
- **Смещение текущих и исторических следов.** Алгоритм не различает актуальные и архивные данные и приписывает устаревшему следу текущее значение.
- **Потеря контекста.** Алгоритм видит ключевое слово, но не понимает смысл фразы целиком — отсюда неверная разметка.
- **Некорректное выделение сущности.** Сущность извлечена неправильно (обрезана, склеена с лишним текстом, не нормализована).
- **Ложные дубли из-за плохой нормализации.** Один и тот же артефакт в разном регистре, с разными пробелами, языковыми формами или параметрами URL воспринимается как разные записи.
- **Слишком расплывчатые или, наоборот, чрезмерно дробные категории.** Если категорий мало и они размыты — теряется смысл; если слишком много — классификация становится неуправляемой.
- **Автоматизация запущена слишком рано** — до того, как студент понял, какие категории следов вообще нужны.

Как с этим бороться: обязательная **ручная верификация** — проверить не менее 10 записей или не менее 20% выборки, зафиксировать типичные ошибки в журнале ошибок, скорректировать классификатор и правила, повторно оценить качество. Автоматический результат всегда показывают вместе с тем, **где алгоритм ошибался и как это исправлено** — иначе доверять разметке нельзя.

69. Что означают понятия сущности, связи, индикатора, источника и уровня уверенности в аналитической работе OSINT?

Это базовый понятийный аппарат для построения **карты связей** и доказательных выводов.

- **Сущность (entity)** — отдельный объект анализа, узел графа. Основные типы сущностей: **субъект** (организация, подразделение, проект, публичная роль, группа — тот, кто действует, владеет, публикует); **ресурс** (публичный цифровой объект или площадка — сайт, поддомен, аккаунт, страница поддержки, документ, репозиторий, форма); **событие** (наблюдаемое действие во времени — публикация, релиз, мероприятие, обновление, инцидент); **индикатор** и **источник** (см. ниже).
- **Связь (relationship)** — отношение между двумя сущностями, подтверждённое или предполагаемое на основе источника. Связь должна иметь **типизацию** («публикует», «упоминает», «содержит», «участвует в», «связан с событием», «владеет», «указывает на индикатор»). Общий тип «связано с» без пояснения недопустим. Важно: **совпадение — это ещё не связь**; связь нуждается в основании.
- **Индикатор (indicator)** — наблюдаемый признак, который помогает связать сущности или подтвердить событие: домен, URL, дата, название сервиса, хештег, контактный адрес,

повторяющаяся формулировка.

- **Источник (source)** — открытый материал, из которого извлекается сущность, связь или индикатор: официальная страница, документ, архивная версия, новость, справочный раздел.
- **Уровень уверенности (confidence)** — оценка того, насколько вывод или связь подтверждаются источниками: **высокий** (несколько независимых/официальных подтверждений), **средний** (один надёжный источник или косвенная корреляция), **низкий** (слабое или одиночное наблюдение).

Эти понятия нужны, чтобы разные аналитики строили **сопоставимые, проверяемые** модели и не смешивали разные типы объектов в одной категории.

70. Каковы принципы построения аналитических графов по открытым данным и каковы ограничения интерпретации выявленных связей?

Аналитический граф (карта связей) — это визуальная и табличная модель отношений между сущностями (субъектами, ресурсами, событиями, индикаторами).

Принципы построения:

- **Граф строится из таблиц, а не рисуется «на глаз».** Основа карты — реестр сущностей и **таблица рёбер графа** (исходный узел, тип связи, целевой узел, источник, подтверждение, дата, уровень уверенности, комментарий). Без таблицы рёбер карта невоспроизводима.
- **Сущности типизируются и нормализуются.** Каждая сущность имеет понятный тип; названия приводятся к единому виду, дубли объединяются.
- **Связи типизируются.** Каждое ребро имеет конкретный тип отношения; «связано с» без пояснения недопустимо.
- **Каждая связь имеет основание.** Указывается источник, подтверждение, дата, уровень уверенности. Связь по косвенному признаку маркируется как вероятная.
- **Уровни уверенности различаются визуально:** подтверждённая связь — сплошная линия, вероятная — пунктир, историческая — линия с пометкой даты.
- **Карта должна быть читаемой и доказательной,** а не декоративной и перегруженной. Лучше компактная, но ясная карта.
- **Анализ структуры:** выделяют центральные узлы, изолированные элементы, «мосты» между группами, повторяющиеся индикаторы, кластеры. Если карта не приводит к аналитическому выводу — это иллюстрация, а не результат.

Ограничения интерпретации связей:

- **Совпадение ≠ связь** — одно и то же название на двух страницах не доказывает устойчивую связь;
- неполнота открытых данных и устаревание сведений;
- косвенные связи лишь вероятны и требуют проверки;
- историческую связь нельзя автоматически переносить на текущее состояние;

- запрещены сильные выводы (о виновности, уязвимости, внутренней структуре) на основе единичного косвенного признака;
- персональные данные используются только в рамках учебной необходимости.

71. Что такое цифровая экспозиция и в чём различие между открытым следом, аналитической интерпретацией, сценарием риска и защитной рекомендацией?

Цифровая экспозиция — это совокупность открыто наблюдаемых сведений об организации, сервисе или цифровом объекте, которые могут **повышать осведомлённость внешнего наблюдателя** о структуре сервисов, ролях, процессах, публикациях, поставщиках, технологиях и логике публичного цифрового присутствия.

Важно: цифровая экспозиция **не тождественна уязвимости**. Сама по себе открытость не означает, что объект «дырявый». Экспозиция становится аналитически значимой тогда, когда отдельные открытые сведения **складываются в интерпретируемую картину** и позволяют формулировать обоснованные защитные рекомендации.

Различие четырёх понятий — это **цепочка защитного сценарного анализа**:

1. **Открытый след** — публично доступное сведение или артефакт, наблюдаемый без активного воздействия на объект. *Это факт, наблюдение.* Пример: вакансия содержит перечень технологических платформ.
2. **Аналитическая интерпретация** — объяснение того, что этот след означает. *Это вывод из факта.* Пример: перечень платформ позволяет предположить используемый технологический стек.
3. **Сценарий риска** — оборонительно сформулированное описание того, как избыточно раскрытые сведения могут повысить информированность внешнего наблюдателя и создать нежелательное последствие. *Это «что может пойти не так».* Пример: избыточная детализация стека в вакансиях повышает информированность внешнего наблюдателя об устройстве объекта.
4. **Защитная мера (рекомендация)** — организационное, публикационное или аналитическое действие, снижающее избыточность раскрытия. *Это «что делать».* Пример: пересмотреть шаблон публикации вакансий, исключить лишние служебные обозначения.

Цепочка целиком: **открытый след → аналитический вывод → сценарий риска → защитная мера**. Сценарий нельзя превращать в инструкцию для нарушителя — формулировки остаются защитными и нейтральными.

72. Каковы ограничения сценарного моделирования, основанного исключительно на открытых данных?

Защитное сценарное моделирование цифровой экспозиции строится только на открытых данных и пассивных методах — отсюда его ограничения:

- **Использовались только открытые источники.** В открытом доступе лишь часть сведений об объекте; модель неизбежно неполна.
- **Активная проверка не проводилась.** Сценарии не подтверждаются техническими методами — нельзя проверить, реализуем ли риск на практике. Сценарий остаётся **гипотезой о возможной экспозиции**, а не доказанным фактом.
- **Часть сведений может быть исторической.** Архивные следы могут уже не отражать текущее состояние и искажать сценарий.
- **Часть связей подтверждена только косвенно.** Многие выводы основаны на косвенных признаках — их уровень уверенности средний или низкий.
- **Открытый след не равен уязвимости.** Экспозиция — не уязвимость; нельзя из факта открытости делать вывод о реальной уязвимости объекта.
- **Невозможность оценить реальный контекст и внутренние меры защиты.** Аналитик не видит внутренних компенсирующих мер организации, поэтому не может оценить риск «как критический» обоснованно.
- **Риск чрезмерно сильных или категоричных выводов.** Запрещены утверждения «объект уязвим», «внутренняя архитектура устроена так-то» — они выходят за пределы доказуемого по открытым данным.
- **Не всякий риск устраним полностью** — после защитной меры остаётся **остаточный риск**.

Вывод: сценарное моделирование по открытым данным даёт **осторожную, вероятностную картину** возможной экспозиции и набор защитных рекомендаций, но не заменяет полноценную техническую оценку защищённости. Ограничения обязательно фиксируются отдельным разделом отчёта.

73. Что означают понятия базовой линии, сигнала, индикатора раннего предупреждения, информационного шума и ложного срабатывания в контексте OSINT-мониторинга?

Это понятийный аппарат **OSINT-мониторинга изменений цифровой экспозиции** — перехода от разового исследования к регулярному наблюдению за динамикой.

- **Базовая линия (baseline)** — исходное зафиксированное состояние открытой цифровой экспозиции объекта на определённый момент или временной срез: основной домен, ключевые публичные контуры, основные типы публикаций, известные страницы поддержки, документации, вакансий, новостей. **Все последующие наблюдения сравниваются именно с базовой линией** — без неё невозможно понять, что именно изменилось.
- **Сигнал** — значимое изменение, которое связано с изменением открытой наблюдаемости объекта и заслуживает внимания специалиста по ИБ. Сигнал должен иметь отношение к цифровой экспозиции (новый контур документации, изменение вакансий, появление страниц разработчиков, упоминание нового поставщика).
- **Индикатор раннего предупреждения** — наблюдаемое открытое изменение, которое может указывать на рост цифровой экспозиции, изменение структуры публичного

контура, появление нового сервисного направления, усиление раскрытия технических сведений, появление рискованной публикации или рост информационного шума. Это **не** технический индикатор компрометации в узком смысле, а именно открытое изменение-«звоночек».

- **Информационный шум** — изменения, которые **не являются значимыми**: дублирующиеся новости, маркетинговые публикации, общие формулировки, обновление дизайна, сезонные вакансии, материалы без отношения к цифровой экспозиции, устаревшие следы без текущего значения. Шум нужно уметь **отделять от сигнала**.
- **Ложное срабатывание** — ситуация, когда наблюдение **ошибочно принято за значимый сигнал**, хотя на деле является шумом или несущественным изменением.

Главная задача мониторинга — **отделять значимые сигналы от шума и ложных срабатываний**, оценивать сигналы по уровню уверенности и приоритету, оформлять карточки предупреждений и формулировать защитные рекомендации. Это переводит OSINT из режима разового поиска в режим регулярной аналитической поддержки информационной безопасности.

ЧАСТЬ 2. Вопросы из практических работ

В этой части по каждой практической работе: **(а)** коротко что и как делается; **(б)** ответы на контрольные вопросы / вопросы для защиты. Многие из этих вопросов уже включены в список выше (Часть 1, вопросы 55–73) — здесь они собраны по практикам, чтобы при подготовке к защите конкретной работы всё было в одном месте.

Практическая работа: Анализ доменной и сетевой инфраструктуры организации/сервиса

Что делается (кратко). Объём 4 ак. часа. Только пассивные и правомерные методы. Студент: заполняет паспорт объекта (вариант, объект, основной домен, цель, ≥3 проверяемые гипотезы) → определяет официальный домен (через контакты, политику конфиденциальности, вакансии, пресс-релизы) → выявляет связанные домены (брендовые, продуктовые, региональные, event, документации, поддержки) и классифицирует их (подтверждённо связанные / вероятно связанные / исторические) → фиксирует публично наблюдаемые поддомены и их функции → собирает DNS- и почтовые признаки (NS, MX, TXT/SPF/DMARC/DKIM) через общедоступные сервисы → анализирует открытые сертификатные журналы → оценивает сетевую принадлежность (хостинг, облако, CDN, автономные системы) → делает исторический анализ (архивные страницы) → сопоставляет инфраструктуру с функциями сервиса → строит схему цифрового контура → формулирует выводы (подтверждённые / вероятные / требующие проверки) и ограничения. Итог: отчёт 8–15 страниц, таблицы артефактов, схема.

Запрещено: сканирование хостов и портов, активный перебор поддоменов, обход ограничений, попытки входа, создание нагрузки на объект, выводы об уязвимостях.

Вопросы для защиты и ответы:

Почему именно этот домен вы считаете основным? — Потому что он подтверждён несколькими официальными признаками: указан в разделе контактов, в политике конфиденциальности и пользовательском соглашении, на страницах вакансий, в пресс-релизах и в связанных официальных сервисах. Основным признаётся домен, который является официальной точкой входа в цифровой контур и подтверждён совокупностью источников, а не одним.

Какие источники подтвердили связь дополнительных доменов с объектом? — Прямое упоминание на официальном сайте или в документах объекта (тогда связь подтверждённая); косвенные признаки — похожая лексика, общая структура документов, совпадающий сервисный паттерн (тогда связь вероятная); сертификатные журналы и архивные источники.

Какие признаки позволили выделить отдельные функциональные контуры? — Назначение поддоменов и разделов: auth/login (аутентификация), help/support (поддержка), docs (документация), api/developer (разработка), blog/news (медиа), static/cdn (статический контент), careers (вакансии). Контуры выделяются по функции, которую выполняет домен/поддомен.

Есть ли признаки использования внешнего провайдера? Чем подтверждается? — Признаки облачной, хостинговой или CDN-модели по общедоступным сведениям о маршрутизации, автономных системах, по DNS- и сертификатным данным. Это публично наблюдаемые признаки, а не результат активной проверки.

Что показал исторический анализ? — Менялись ли домены, структура сайта, названия разделов, продуктовые контуры, адреса поддержки, брендовые обозначения — по архивным версиям страниц и старым документам. Историческое нельзя переносить на текущее состояние.

Какие выводы подтверждённые, а какие вероятные? — Подтверждённые опираются на несколько независимых/официальных источников; вероятные — на один источник или косвенные признаки; отдельно выделяются требующие проверки.

Каковы ограничения исследования? — Неполнота открытых данных; изменение инфраструктуры во времени; пассивный характер (без активной проверки); часть связей косвенная. (См. также вопрос 62.)

■ Контрольные вопросы 55, 56, 57, 58 этой практики подробно разобраны в Части 1.

Практическая работа: Выявление технических следов и потенциально рискованных публикаций

Что делается (кратко). Объём 4 ак. часа. Защитная OSINT-аналитика, только пассивные методы. Студент: заполняет паспорт объекта → определяет публичный цифровой контур → составляет реестр открытых источников → выявляет технические следы (только пассивно: домены, поддомены, страницы входа, наименования платформ, облачных решений, help-центров, почтовых шаблонов) → классифицирует следы по категориям (доменные, почтовые, инфраструктурные, организационно-ролевые, документальные, визуальные, исторические) → находит потенциально рискованные публикации (вакансии с лишним стеком, скриншоты с адресами, PDF с техсхемами, инструкции, слайды о миграции) → оценивает риск каждой

публикации (низкий / средний / высокий) → делает исторический анализ → сопоставляет публикации и следы → строит таблицы и схему публично раскрываемого цифрового контура → формулирует выводы и ограничения. Минимум: ≥8 техследов, ≥5 рискованных публикаций, ≥4 типа источников.

Ключевая идея. Цель — не поиск уязвимостей, а оценка **информационной экспозиции**: какие публикации делают цифровую инфраструктуру слишком прозрачной. Один артефакт редко опасен сам по себе — риск возникает в совокупности.

Оценка риска публикации: *низкий* — общие сведения, почти не помогают реконструировать среду; *средний* — даёт представление о сервисах/поставщиках/ролях/стеке, но без системного описания; *высокий* — раскрывает набор взаимосвязанных деталей (названия сервисов, роли, контуры, адресные шаблоны, схемы маршрутов, скриншоты с деталями среды).

Вопросы для защиты и ответы:

Почему выбранные публикации относятся к рискованным? — Потому что они сообщают о цифровой инфраструктуре больше, чем нужно для нормальной публичной коммуникации, и повышают информированность внешнего наблюдателя о ролях, сервисах, поставщиках и взаимодействиях.

Какие технические следы вы считаете наиболее надёжно подтверждёнными? — Те, что подтверждены несколькими независимыми или официальными источниками (например, домен, указанный на официальном сайте и в документах одновременно).

Какие выводы нельзя делать по вашим данным и почему? — Нельзя делать категоричные выводы об уязвимости, защищённости и внутреннем устройстве систем — это выходит за пределы доказуемого по открытым данным и за рамки пассивного анализа.

Как разные публикации дополняют друг друга? — Каждая публикация раскрывает фрагмент; в совокупности они складываются в картину ролей, сервисов, поставщиков и контуров — поэтому анализируются совместно.

Какие публикации объекту стоило бы излагать аккуратнее? — Те, что избыточно раскрывают стек, служебные обозначения, адреса, схемы; рекомендация формулируется нейтрально (сократить детализацию).

Почему работа остаётся в рамках пассивного анализа? — Используются только открытые источники и пассивное наблюдение, без сканирования, перебора, попыток входа и воздействия на объект.

■ Контрольные вопросы 57, 58 этой практики подробно разобраны в Части 1.

Практическая работа 3: Реконструкция публичного цифрового контура организации

Что делается (кратко). Объём 4 ак. часа. Многоканальная реконструкция: студент показывает, что цифровой контур нельзя свести к одному сайту. Шаги: формулирует объект и цель (отличает объект от его цифровых проявлений) → определяет основной домен и базовый контур → выявляет связанные домены и поддомены (различая подтверждённые и вероятные

связи) → собирает публикационные и документационные следы (help, FAQ, политики, пресс-релизы) → собирает кадровые и организационные следы (вакансии, роли) → фиксирует технические и сервисные признаки → строит **карту цифрового контура** → разделяет выводы по уровням уверенности → готовит итоговый отчёт. Итог: отчёт 8–15 страниц, реестр артефактов, карта контура.

Контрольные вопросы и ответы:

Что понимается под публичным цифровым контуром организации? — См. вопрос 59: совокупность публично наблюдаемых доменных, сервисных, публикационных, кадровых, документационных и исторических следов, описывающих цифровое присутствие объекта; контур не сводится к одному сайту.

Почему основной домен нельзя считать достаточным описанием цифрового присутствия? — Потому что цифровой контур включает множество отдельных контуров (поддержки, документации, вакансий, аутентификации, медиа, разработки, внешних сервисов); один сайт — лишь часть картины.

Какие классы открытых источников особенно важны для реконструкции? — См. вопрос 60: доменные/сервисные, документационные, кадровые, публикационные, технические признаки, исторические источники.

Чем подтверждённая связь отличается от вероятной? — Подтверждённая связь прямо упомянута на официальном сайте или в документах объекта; вероятная выводится косвенно (похожая лексика, общий паттерн) и требует пометки и дополнительной проверки.

Какую роль играют help-ресурсы и документация в OSINT-анализе? — Они часто дают больше информации о функциональных контурах, чем сам главный сайт: раскрывают названия сервисов, служебные разделы, адреса поддержки, упоминания партнёрских платформ, пользовательские пути.

Почему кадровые публикации полезны для уточнения цифрового контура? — Вакансии и профили ролей показывают наличие отдельных команд, процессов поддержки, аналитики, разработки, эксплуатации, ИБ — то есть уточняют организационный и технологический контур.

Зачем в отчёте выделять ограничения исследования? — Чтобы выводы были честными и воспроизводимыми: открытые данные неполны, меняются во времени, часть связей косвенная, активная проверка не проводилась. (См. вопрос 62.)

Почему карта цифрового контура важнее простого списка артефактов? — Потому что цель — аналитическая модель, а не каталог ссылок: карта показывает, как элементы соотносятся, какую функцию выполняют и с каким уровнем уверенности связаны с объектом.

■ Вопросы 59, 60, 61, 62 этой практики подробно разобраны в Части 1.

Практическая работа 4: Сравнительный OSINT-анализ цифровых контуров нескольких организаций одной отрасли

Что делается (кратко). Объём 4 ак. часа. Переход от описания одного объекта к сравнительному анализу группы. Шаги: студент выбирает 3–5 сопоставимых объектов одной

отрасли → оформляет паспорт исследования → определяет основные цифровые контуры объектов → собирает публикационные и организационные следы → выбирает 6–10 единых критериев сравнения → строит **сравнительную матрицу** (критерии по строкам, объекты по столбцам) → выделяет сходства, различия и отраслевые паттерны → оценивает наблюдаемую цифровую зрелость → готовит визуализацию → формулирует итоговый вывод. Итог: отчёт 10–16 страниц, карточки объектов, сравнительная матрица, визуализация.

Контрольные вопросы и ответы:

Что такое сравнительный OSINT-анализ? — Это анализ, где каждый вывод опирается не на данные по одному объекту, а на единые критерии сопоставления для нескольких объектов; цель — увидеть паттерны и оценить цифровую зрелость.

Почему для сравнения нужно выбирать сопоставимые объекты? — Объекты должны быть сопоставимы по типу деятельности, масштабу и модели цифрового присутствия — иначе сравнение некорректно (нельзя сравнивать несопоставимое).

Зачем нужна единая система критериев? — Чтобы все объекты оценивались одинаково, по одной шкале; без единых критериев сравнение превращается в последовательное описание объектов.

Какие следы наиболее важны при сравнении цифровых контуров? — Доменные, сервисные, публикационные, организационные (кадровые), исторические следы и признаки внешних зависимостей.

Чем отличается описание объекта от сравнительного анализа? — Описание характеризует один объект; сравнительный анализ сопоставляет объекты по единым критериям и выявляет отраслевые паттерны и индивидуальные различия.

Почему визуализация важна для итогового вывода? — Сравнительная матрица, карта контуров или диаграмма делают сопоставление наглядным и помогают увидеть структуру, которую трудно заметить в тексте.

Как различать подтверждённые и вероятные выводы? — По уровню уверенности: подтверждённые опираются на несколько независимых источников, вероятные — на один или косвенные признаки.

Какие ограничения имеет исследование цифровых контуров по открытым данным? — См. вопрос 62: неполнота, изменение во времени, косвенность части связей, пассивный характер.

❏ Вопросы 63, 64 этой практики подробно разобраны в Части 1.

Практическая работа 5: Частичная автоматизация OSINT-анализа открытых технических следов

Что делается (кратко). Объём 4 ак. часа. Студент строит небольшой аналитический конвейер (гибридный процесс). Шаги: заполняет паспорт объекта (≥3 гипотезы) → формирует план сбора и реестр источников → вручную собирает ≥30 открытых технических следов → нормализует данные и удаляет шум/дубли → проектирует классификатор (5–8 категорий + поля: тип источника, историчность, уровень значимости, признак подтверждения) → реализует

частичную автоматизацию (формулы таблиц, регулярные выражения, словари ключевых слов, простые скрипты) → проверяет качество автоматической разметки вручную (≥ 10 записей или $\geq 20\%$ выборки) → ведёт журнал ошибок → формирует итоговые таблицы и аналитическую справку. Итог: отчёт 8–12 страниц, таблица следов (≥ 30 записей), таблица автоматизированной классификации (≥ 5 полей автоматизации), журнал ошибок, аналитическая справка.

Ключевая идея. Студент автоматизирует **структурирование уже найденных открытых данных**, а не сбор любой ценой и не воздействие на объект. Автоматизация ускоряет обработку, но не заменяет экспертизу: человек определяет категории → автоматизирует повторяющееся → проверяет результат вручную.

Вопросы для защиты и ответы:

Почему выбранные категории достаточны для объекта? — Категории покрывают основные типы технических следов объекта (доменные, контактные, архитектурные, организационно-технологические, процессные, исторические) и не слишком дробные/расплывчатые.

Какие типы следов оказались наиболее информативными? — Обычно вакансии, разделы документации и публичные пользовательские соглашения — они дают наибольшее число структурируемых следов.

Какие операции вы автоматизировали и почему? — Безопасные аналитические операции: очистку, удаление дублей, выделение сущностей, тематическую разметку по словарям ключевых слов, классификацию (см. вопрос 67) — потому что они повторяющиеся и хорошо формализуются.

Как вы проверяли качество автоматической классификации? — Вручную проверял ≥ 10 записей или $\geq 20\%$ выборки, фиксировал типичные ошибки в журнале, корректировал классификатор, повторно оценивал качество.

Какие ошибки алгоритма были наиболее частыми? — Ложные срабатывания, неверная категория, смешение текущих и исторических следов, потеря контекста, ложные дубли из-за плохой нормализации (см. вопрос 68).

Как вы отделяли текущие следы от исторических? — По признаку историчности (текущий / архивный / неясно), по архивным версиям страниц и датам публикаций.

Какие ограничения есть у подхода? — Автоматизация не понимает контекст и ошибается; работает только с уже найденными открытыми данными; не заменяет экспертную интерпретацию.

■ Вопросы 65, 66, 67, 68 этой практики подробно разобраны в Части 1.

Практическая работа 6: Составление карты связей между субъектами, ресурсами, событиями и индикаторами

Что делается (кратко). Объём 4 ак. часа. Переход от классификации отдельных следов к построению аналитического графа. Шаги: студент формулирует аналитическую задачу (как вопрос, а не «найти всё») → определяет типы сущностей (субъект, ресурс, событие, индикатор, источник) → составляет реестр источников → выделяет и нормализует сущности → определяет

типы связей → фиксирует доказательства каждой связи и уровень уверенности → строит **таблицу рёбер графа** → строит **карту связей** → анализирует структуру (центральные узлы, кластеры, мосты) → формулирует выводы и ограничения. Минимум: ≥15 сущностей, ≥20 связей, ≥4 типа сущностей, ≥3 типа связей, ≥8 связей со средним/высоким уровнем уверенности. Итог: отчёт 8–15 страниц, реестр сущностей, реестр связей, карта связей с легендой.

Контрольные вопросы и ответы:

Какова цель вашей карты связей? — Построить проверяемую модель отношений между сущностями, которая показывает структуру цифровой экосистемы объекта и приводит к аналитическому выводу.

Какие типы сущностей вы использовали и почему? — Субъект, ресурс, событие, индикатор, источник — это минимальный набор, позволяющий не смешивать разные типы объектов в одной категории (см. вопрос 69).

Какие связи наиболее надёжно подтверждены? — Те, что имеют несколько независимых оснований (прямое указание в официальном источнике + повторяющийся индикатор).

Какие связи вероятны и требуют проверки? — Основанные на косвенных признаках (повторяющиеся формулировки, совпадающие индикаторы без прямого подтверждения).

Какие источники дали наибольшее число подтверждений? — Обычно официальные страницы и документы объекта.

Какие узлы можно считать центральными? — Сущности с наибольшим числом подтверждённых связей (основной субъект, официальные ресурсы).

Какие ограничения имеет ваша карта? — Совпадение ≠ связь; неполнота данных; косвенность части связей; историческое нельзя переносить на текущее; пассивный характер (см. вопрос 70).

Что изменилось бы при исключении одного источника? — Связи, опиравшиеся только на него, стали бы слабее или перешли в разряд требующих проверки — это проверка устойчивости карты.

Почему работа остаётся в рамках пассивного OSINT-анализа? — Используются только открытые данные, без сканирования, перебора, воздействия.

Какую практическую ценность имеет карта для ИБ? — Помогает увидеть структуру связей, которую невозможно заметить при простом чтении отдельных страниц; полезна для threat intelligence и защитной аналитики.

■ Вопросы 69, 70 этой практики подробно разобраны в Части 1.

Практическая работа 7: Подготовка итогового аналитического OSINT-отчёта

Что делается (кратко). Объём 4 ак. часа. Завершающая работа: все элементы предыдущих практик объединяются в целостный аналитический продукт. Шаги: студент выбирает вариант и объект → формулирует **аналитический вопрос** (конкретный, проверяемый) → заполняет паспорт мини-исследования → собирает и нормализует исходные материалы → строит **матрицу**

доказательств (каждый вывод связан с источниками) → разделяет факты, гипотезы и интерпретации → оценивает уровни уверенности → готовит визуализацию → формулирует выводы и защитно-ориентированные рекомендации → готовит мини-защиту (5–7 минут). Итог: отчёт 10–16 страниц, матрица доказательств, визуализация, разделы «подтверждено / вероятно / требует проверки», ≥3 рекомендации.

Ключевая идея. Отчёт строится по принципу **трассируемости**: каждое существенное утверждение имеет источник, уровень уверенности и объяснение. Сильный отчёт показывает не объём текста, а прозрачность связи между источниками и выводами.

Уровни уверенности и формулировки: высокий (несколько независимых подтверждений) — «подтверждённо установлено»; средний (один сильный источник или несколько косвенных признаков) — «вероятно», «наблюдаются признаки»; низкий (фрагментарные данные) — «можно предположить», «требует проверки»; недостаточный — «недостаточно данных для вывода».

Вопросы для мини-защиты и ответы:

Какой аналитический вопрос лежал в основе отчёта? — Конкретный проверяемый вопрос (например, «какие открытые публикации формируют цифровую экспозицию сервиса?»), задающий весь отчёт.

Почему выбранные источники достаточны? — Они разнообразны, релевантны, охватывают нужные классы (домены, документы, вакансии, публикации) и позволяют связать наблюдения между собой.

Какие выводы подтверждённые, а какие вероятные? — Подтверждённые — несколько независимых источников; вероятные — один источник или косвенные признаки.

Как вы отделяли факт от интерпретации? — Факт прямо зафиксирован в источнике; гипотеза — предположение по совокупности признаков; интерпретация — объяснение значения. Эти уровни разведены в тексте и таблицах.

Какая визуализация ключевая и почему? — Та, что помогает главному выводу (карта связей, схема контура, матрица рисков, временная шкала) — она не декоративна, а функциональна.

Какие ограничения имеет исследование? — Только открытые данные, пассивный характер, неполнота, косвенность части выводов (см. вопрос 62).

Какие рекомендации наиболее значимы? — Защитно-ориентированные: улучшить публикационную дисциплину, сократить избыточную детализацию, убрать устаревшие материалы, унифицировать контур.

Что изменилось бы при появлении дополнительных источников? — Часть вероятных выводов могла бы стать подтверждённой или, наоборот, опровергнута.

Какие данные вы сознательно не использовали и почему? — Закрытые, сомнительного происхождения, чувствительные детали — из-за правовых и этических ограничений.

Почему работа остаётся в рамках пассивного OSINT? — Только открытые источники, без активной проверки и воздействия.

Практическая работа 8: Защитное сценарное моделирование цифровой экспозиции

Что делается (кратко). Объём 4 ак. часа. Работа повышенного уровня: переход от поиска следов к **сценарному риск-моделированию**. Студент может использовать результаты предыдущих практик как исходный материал. Шаги: определяет объект, границы и исходный материал → заполняет паспорт сценарного исследования → группирует открытые следы по категориям цифровой экспозиции → строит цепочки «**открытый след → аналитический вывод → сценарий риска → защитная мера**» (≥5 цепочек) → оценивает каждый сценарий (вероятность, влияние, уровень уверенности, приоритет) → разрабатывает защитные меры → оценивает остаточный риск → строит визуализацию → формулирует итоговый вывод. Итог: отчёт 10–16 страниц, матрица сценариев, матрица защитных мер, ≥12 исходных следов, ≥5 сценариев, ≥5 рекомендаций.

Ключевая идея. Цель — не «как атаковать», а «что организации публиковать аккуратнее и как снизить избыточную открытость». Сценарий нельзя превращать в инструкцию для нарушителя. Цифровая экспозиция ≠ уязвимость.

Контрольные вопросы и ответы:

Что понимается под цифровой экспозицией организации? — См. вопрос 71: совокупность открыто наблюдаемых сведений, повышающих осведомлённость внешнего наблюдателя; не тождественна уязвимости.

Чем сценарное моделирование отличается от поиска технических следов? — Поиск следов — это сбор и классификация; сценарное моделирование — построение цепочек «след → вывод → риск → мера» и оценка риска.

Почему открытый след не является автоматически уязвимостью? — След лишь повышает информированность наблюдателя; уязвимость — это конкретная техническая слабость, которую по открытым данным доказать нельзя.

Как связать открытый артефакт с возможным сценарием риска? — Через цепочку: след → аналитическая интерпретация → защитно сформулированный сценарий → мера (см. вопрос 71).

Что такое уровень уверенности в сценарном анализе? — Оценка подтверждённости вывода источниками (высокий/средний/низкий).

Почему рекомендации должны быть защитно-ориентированными? — Потому что цель работы — снизить риск организации, а не дать преимущество нарушителю.

Какие формулировки недопустимы? — «Объект уязвим», «внутренняя архитектура устроена так-то», сценарий как инструкция для нарушителя.

Как оценить остаточный риск после меры? — Кратко описать, что изменится после реализации меры и какой риск останется (не всякий риск устраним полностью).

Почему исторические сведения создают цифровой шум? — Устаревшие данные могут искажать картину текущего состояния объекта.

Как отличить управленческую рекомендацию от технической гипотезы? — Рекомендация — это действие по снижению экспозиции (организационное/публикационное); гипотеза — предположение о состоянии объекта.

Вопросы 71, 72 этой практики подробно разобраны в Части 1.

Практическая работа 9: OSINT-мониторинг изменений цифровой экспозиции

Что делается (кратко). Объём 4 ак. часа. Продвинутая работа: переход от разового исследования к проектированию **системы регулярного мониторинга**. Шаги: студент выбирает объект и определяет границы мониторинга → формулирует гипотезы мониторинга → фиксирует **базовую линию** цифровой экспозиции → разрабатывает **каталог индикаторов** → составляет карту источников наблюдения → ведёт **журнал наблюдений** (≥12 наблюдений) → отделяет сигнал от шума → оценивает уровень уверенности и приоритет каждого сигнала → готовит **карточки предупреждений** (≥3) → строит мониторинговую сводку → формулирует защитные рекомендации и ограничения. Минимум: ≥8 индикаторов, ≥6 классов источников, ≥12 наблюдений, ≥5 значимых сигналов, ≥3 карточки предупреждений.

Ключевая идея. Разовое исследование показывает, как объект выглядит сейчас; мониторинг отвечает на вопрос «что изменилось». Базовая линия — точка отсчёта; всё сравнивается с ней. Главный навык — отделять значимые сигналы от информационного шума.

Вопросы для защиты и ответы:

Что в вашей работе является базовой линией? — Исходное зафиксированное состояние открытой цифровой экспозиции объекта: основной домен, ключевые контуры, типы публикаций, известные страницы поддержки/документации/вакансий/новостей (см. вопрос 73).

Какие индикаторы вы выбрали и почему? — Наблюдаемые признаки изменений, связанные с цифровой экспозицией (новый домен/раздел, новая документация, изменение вакансий, появление страниц разработчиков, упоминание нового поставщика) — потому что они отражают рост или изменение наблюдаемости объекта; каталог не должен быть слишком широким для 4 часов.

Какие источники оказались наиболее информативными? — Обычно официальный сайт, раздел вакансий, документация, help-центр, блог, архив страниц.

Какие наблюдения вы отнесли к шуму? — Дублирующиеся новости, маркетинговые публикации, общие формулировки, обновление дизайна, сезонные вакансии — то, что не меняет представление о цифровой экспозиции (см. вопрос 73).

Какие сигналы получили высокий приоритет и почему? — Сигналы, сочетающие значимость, новизну, подтверждённость и потенциальную полезность для внешнего наблюдателя. Высокий приоритет ≠ уязвимость — это значит, что сигнал заслуживает внимания при оценке экспозиции.

Как вы определяли уровень уверенности? — Высокий — несколько независимых/официальных источников; средний — один надёжный источник или косвенная корреляция; низкий — слабое

или одиночное наблюдение.

Какие защитные рекомендации следуют из наблюдений? — Пересмотреть детализацию публикаций, унифицировать справочные материалы, удалить устаревшие инструкции, обозначить владельцев цифровых контуров, ввести регулярную проверку открытых публикаций.

Какие ограничения имеет модель мониторинга? — Только открытые данные, пассивный характер, ограниченное время наблюдения, риск ложных срабатываний.

Как развить работу в долгосрочный процесс? — Сделать наблюдение регулярным, расширить каталог индикаторов, автоматизировать сбор и фильтрацию, вести историю изменений базовой линии.

Вопрос 73 этой практики подробно разобран в Части 1.

Практики из лекций (упоминаются, без отдельных методичек)

В лекциях упоминается ещё ряд практических заданий — кратко, что в них делается:

- **Поиск преподавателя/человека по открытым источникам** — найти максимум информации о человеке только из открытых источников; чем больше найдено, тем выше балл.
- **Геолокация фото** — по фотографиям определить вид животных/растений/птиц, их ареал, повадки, возможное место съёмки; составить отчёт (HackMD/Notion) с разделами «извлечь, исследовать, проверка», скринами, панорамами.
- **MetaExtractor / ExifTool** — извлечение метаданных из PDF, офисных документов и фотографий (автор, ПО, даты, геолокация).
- **Сканирование Nmap** — изучение сканера портов как эталонного инструмента разведки.
- **pwdlogy + crunch** — составление профильных словарей паролей под жертву и генерация словарей по паттерну.
- **sshprank + Masscan** — развернуть SSH-сервер, просканировать свою сеть, составить словари, подобрать логин:пароль к SSH, разобраться, как Masscan работает совместно с Nmap (учебная отработка механики атаки на своей сети).
- **MITM на SSH** — установить SSH MITM, освоить tcpdump, arpspoof, iptables, понять файл known_hosts, выполнить учебную атаку «человек посередине» на SSH в своей сети, проанализировать auth.log. Цель — **понять процесс, чтобы знать, на каких стадиях защищаться.**
- **Git, apt-get** — освоение базовых инструментов (клонирование репозитория, установка пакетов в Linux).

Все «атакующие» практики из лекций выполняются **только в собственной учебной сети** и нужны, чтобы понять механику атаки и научиться от неё защищаться.

ЧАСТЬ 3. Шпаргалка на 20 минут (вся теория и практики кратко)

Это сжатая версия всего курса. Прочитайте её вечером перед сном — и утром подробные ответы будут читаться легко, потому что вы уже будете знать «каркас».

А. Главные понятия одной строкой

- **OSINT** — разведка по открытым источникам. Сбор и анализ информации из открытого доступа, без взлома.
- **Технологии OSINT делятся на пассивные и активные.** Пассивные — только чтение открытого, законны. Активные — взаимодействие с системой объекта, выходят за рамки OSINT.
- **90% информации в OSINT даёт обычное чтение.** Решает квалификация аналитика, инструменты вторичны.
- **Цифровой контур** — всё публичное цифровое присутствие организации (не один сайт, а множество контуров: поддержка, документация, вакансии, вход, медиа, разработка).
- **Цифровая экспозиция** — совокупность открытых сведений, повышающих осведомлённость наблюдателя. Экспозиция ≠ уязвимость.
- **Технический след** — публично наблюдаемый артефакт (домен, e-mail, имя сервиса), помогающий реконструировать инфраструктуру.
- **Уровни уверенности:** подтверждено (несколько источников) / вероятно (один источник или косвенно) / требует проверки / недостаточно данных.
- **Главное правило аналитики:** совпадение ≠ связь; один источник недостаточен; не делать категоричных выводов; всегда указывать ограничения.

Б. Технологии и инструменты OSINT

- **Метаданные** — скрытые данные в файлах (автор, ПО, дата, геолокация). Формат фото — EXIF (включает GPS), ещё XMP, IPTC. Инструменты: ExifTool, MetaExtractor, FOCA.
- **Поиск по изображениям** — проверить, откуда фото (Google Images, Yandex, TinEye).
- **Данные о домене** — e-mail, телефоны, технологии, сертификаты, субдомены.
- **Интернет вещей** — индексация устройств без взлома. Поисковик — **Shodan** («тёмный близнец Google»): краулеры сканируют интернет, по fingerprint определяют сервис за портом.
- **Google Dorks** — операторы расширенного поиска: кавычки (точная фраза), **OR**/**|**, минус (исключить), **site:**, **inurl:**, **filetype:**, **related:**, **info:**, **cache:**, **define:**, **~** (синонимы), **..** (диапазон), ***** (любое слово).
- **Поиск по e-mail/никнейму:** Emailsherlock, WhatsMyName, Maigret (форк Sherlock, 2300+ сайтов).
- **Визуализация связей:** Maltego, Analyst's Notebook.
- **Сканеры портов:** Nmap (эталон), Masscan (самый быстрый — весь интернет за 6 минут).

- **ОС для работы:** Kali Linux (с SET, theHarvester, Recon-ng), Trace Labs (форк для OSINT), Tails (анонимная ОС).
- **Анонимность:** Tor (цепочка ≥ 3 узлов, выходной узел — слабое место), VPN, прокси.

В. Целевые атаки

- **Целевая атака** — непрерывный, управляемый в реальном времени процесс несанкционированной активности против конкретной жертвы. Три свойства: непрерывность, целенаправленность, нетривиальность.
- **Жизненный цикл атаки:** Разведка → Доставка → Эксплуатация → Закрепление → Действие (lateral movement + exfiltration) → Противодействие.
- **Разведка vs эксплуатация:** разведка — «смотрю и собираю» (пассивно, незаметно); эксплуатация — «вламываюсь и использую» (активно, заметно).
- **Фреймворк социальной инженерии:** Обзор → Разведка → Проектирование и согласование → Реализация → Обнаружение → Измерение → Отчёт.
- **Цикл НОРД/OODA:** Наблюдение → Ориентация (гипотеза) → Решение → Действие, повторять итеративно.
- **Подготовка к атаке:** согласование с клиентом → ознакомление с задачей → ТЗ → юридическая защита (страховка E&O) → определение целей и методов → разработка предложений (3-5 вариантов на выбор клиента).
- **Точки входа:** серверы/панели на периметре, мобильные устройства сотрудников, облачные аккаунты. Периметр размывается из-за облаков и BYOD.

Г. Социальная инженерия и психология

- **Социальная инженерия (социотехника)** — приёмы психологической манипуляции. Берёт концепции из психологии.
- **Влияние** — нейтральная мотивация; **манипуляция** — пагубное влияние, направленное на вред.
- **Раппорт** — взаимное доверие. **Симпатия** — забота о другом; **эмпатия** — переживание тех же чувств.
- **6 принципов Чалдини:** Авторитет, Привлекательность, Срочность/Дефицит, Постоянство/Последовательность, Социальное доказательство, Взаимность.
- **Этическая социальная инженерия:** контракт + ТЗ, письменное разрешение, соблюдение границ (попросили остановиться — остановись), учёт спуфинга и записи разговоров, защита психики объекта, цель — обучение.
- **Виды атак, связанных с OSINT:** спам (массовые рассылки, шпионский пиксел 1×1, нельзя «отписываться»), вирусы (трояны, кейлоггеры, руткиты), фишинг (выуживание паролей и данных карт; spear phishing — целевой), вымогательство (крючок — страх; «письмо от хакера»).
- **Телефонное мошенничество:** «нет времени объяснять», «звонок из банка», запугивание, жадность, запись голоса для авторизации, подмена номера.

Д. Методы поиска информации

- **Обычные поисковики** (Google, Bing) — сканер индексирует сайты, выдача ранжируется; алгоритм ранжирования секретный.
- **Приватные поисковики** (не отслеживают) — DuckDuckGo, Qwant, Swisscows, Oscobo, Gigablast, Gibiru.
- **Метапоисковики** — нет своего индекса, опрашивают много поисковиков сразу (eTools, Carrot2, All the Internet).
- **Национальные поисковики** — Yandex (РФ), Baidu (Китай), Goo (Япония) и др.
- **Бизнес-поиск** — годовые отчёты (annualreports.com, SEC EDGAR) и профили компаний (OpenCorporates, Crunchbase, Companies House, LittleSis).
- **Серая литература** — материалы вне коммерческих издательств: научные работы, отчёты, диссертации, стандарты (Google Scholar, Academia, ScienceDirect, BASE).
- **Архивы** — Wayback Machine (308+ млрд страниц), archive.fo.
- **Специализированные поисковики:** код (Searchcode, GitHub Dorks), FTP, IoT (Shodan, Insecam), изображения, видео.
- **Обнаружение фейков:** прочитать целиком → проверить источник → перейти к первоисточнику → перекрёстная проверка. Сервисы: Snopes, Hoaxy, FactCheck, InVID.
- **Утечки данных** — статус спорный; обращаться осторожно, не обнаруживать персональные/частные данные. Репозитории: WikiLeaks, Cryptome, Offshore Leaks.
- **Главный принцип поиска:** использовать несколько поисковиков сразу — результаты сильно различаются; перед поиском анонимизироваться.

Е. Сетевые основы (из лекций)

- **IP-адрес** — 32 бита, 4 октета (числа 0-255). Зарезервированные диапазоны: 10.0.0.0/8, 172.16.0.0/12, 192.168.0.0/16, 127.0.0.0/8.
- **IPv6** — 128 бит, 8 сегментов по 16 бит, шестнадцатеричная запись. Сокращения: убирать начальные нули, (::) заменяет подряд идущие нулевые группы (один раз). Глобальные IPv6 начинаются с «2» или «3». IP и IPv6 — две параллельные сети; при анализе трафика нельзя забывать про IPv6.
- **MAC-адрес** — физический адрес сетевого интерфейса, 6 пар символов. Первые 3 октета (OUI) — производитель (база oui.txt от IEEE). MAC виден только в локальной сети, не передаётся на сайты. MAC можно подменять (спуфинг).
- **Управляющие протоколы:** ICMP (сообщения об ошибках), ARP (сопоставление IP ↔ MAC), DHCP (автоматическая выдача IP).
- **MITM (man-in-the-middle)** — атака «человек посередине»: злоумышленник вклинивается между жертвой и сервером (поддельный Wi-Fi, ARP-спуфинг, DNS-спуфинг). Дешифрация — HTTPS-спуфинг, SSL Hijacking, SSL Stripping. Защита: избегать открытого Wi-Fi, VPN, проверять HTTPS и замочек, мультифакторная аутентификация.

- **SSH** — защищённое подключение к удалённому компьютеру. Защита от MITM — файл `known_hosts` (хранит отпечаток сервера; при смене отпечатка выдаётся предупреждение).

Ж. Защита и приватность (из лекции 6)

- **Первая линия защиты** — антивирус + персональный брандмауэр (фаервол). Дополнительно — антивредоносное ПО.
- **Усиление ОС:** обновления, ограниченная учётная запись (не админ), надёжные пароли, UAC, отключение лишних служб и портов, пароль на BIOS/UEFI.
- **Уничтожение данных:** физическое разрушение, размагничивание (для HDD), логическое (перезапись). С SSD данные восстановить сложнее (команда TRIM).
- **Методы слежки:** по IP, cookie (сессионные и постоянные — flash/ever cookies), **цифровые отпечатки браузера** (fingerprinting — на основе сценариев и canvas; stateless tracking). Проверка: browserleaks, panopticklick, amunique.
- **Анонимность:** VPN (выбирать свой DNS, OpenVPN, анонимная оплата), Tor (≥ 3 узла), Tails OS. Опасность — утечки DNS (проверка на dnsleaktest.com).
- **Шифрование:** дисков (VeraCrypt, BitLocker, DiskCryptor), облака (шифровать перед загрузкой — Cryptomator, Duplicati), почты (TorBirdy).
- **Виртуализация** — изоляция (VMware, VirtualBox); для конфиденциальных задач — Tails с LiveUSB.

3. Все 9 практических работ — суть в двух строках каждая

1. **Доменная и сетевая инфраструктура.** Пассивно определить основной домен, связанные домены, поддомены, DNS/почтовые/сертификатные/сетевые признаки → схема цифрового контура → выводы по уровням уверенности.
2. **Технические следы и рискованные публикации.** Выявить и классифицировать технические следы; найти публикации, избыточно раскрывающие инфраструктуру; оценить риск (низкий/средний/высокий) → защитные рекомендации.
3. **Реконструкция цифрового контура.** Показать, что контур $\neq$ один сайт: собрать доменные, документационные, кадровые, технические следы → построить карту цифрового контура.
4. **Сравнительный анализ.** Выбрать 3–5 сопоставимых объектов одной отрасли, единые 6–10 критериев → сравнительная матрица → отраслевые паттерны и различия.
5. **Частичная автоматизация.** Собрать ≥ 30 следов вручную → нормализовать → классификатор → автоматическая разметка (таблицы, regex, словари) → ручная проверка $\geq 20\%$ → журнал ошибок.
6. **Карта связей.** Сущности (субъект/ресурс/событие/индикатор/источник) + типизированные связи + доказательства → таблица рёбер графа → карта связей с легендой.
7. **Итоговый аналитический отчёт.** Аналитический вопрос → матрица доказательств (вывод $\leftrightarrow$ источник $\leftrightarrow$ уверенность) → разделить факт/гипотезу/интерпретацию → визуализация → рекомендации → мини-защита.

8. **Сценарное моделирование экспозиции.** Цепочки «след → вывод → сценарий риска → защитная мера» (≥ 5) → оценка вероятности/влияния/приоритета → матрица защитных мер → остаточный риск.
9. **Мониторинг изменений.** Зафиксировать базовую линию → каталог индикаторов → журнал наблюдений (≥ 12) → отделить сигнал от шума → карточки предупреждений → защитные рекомендации.

Общее для всех практик: только открытые данные, только пассивные методы; никакого сканирования, перебора, попыток входа, воздействия на объект; объём 4 ак. часа; итог — отчёт 8–16 страниц с таблицами, схемой/визуализацией, выводами по уровням уверенности и обязательным разделом ограничений. Запрещены категоричные выводы «объект уязвим».

И. 7 правил, которые спасут на защите любой работы

1. **Только открытые данные и пассивные методы.** Если спрашивают про границы — отвечайте, что не делали сканирования, перебора, попыток входа, воздействия на объект.
2. **Совпадение $\neq$ связь.** Связь нужно подтверждать основанием и источником.
3. **Один источник недостаточен.** Сильный вывод — это несколько независимых подтверждений.
4. **Разделяйте уровни уверенности:** подтверждено / вероятно / требует проверки.
5. **Не путайте факт, гипотезу и интерпретацию.** Факт — в источнике; гипотеза — предположение; интерпретация — объяснение.
6. **Цифровая экспозиция $\neq$ уязвимость.** Нельзя говорить «объект уязвим» — только «наблюдается избыточное раскрытие сведений».
7. **Всегда называйте ограничения исследования:** неполнота открытых данных, изменение во времени, косвенность части связей, пассивный характер (без активной проверки).

Конец документа. Удачи на сдаче!